



流量識別與分析技術

李琦

清華大學網研院



本章的內容組織

攻擊流量的檢測和防禦

從海量的數據包當中抽取流量特徵，推斷攻擊流量是否為正常或者異常，從而實現檢測和攔截攻擊流量，保護大量互聯網用戶的安全性

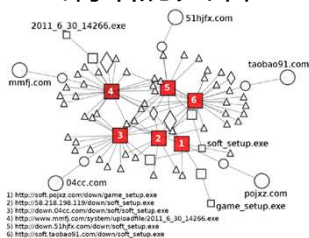
流量特徵隱私竊取

根據加密流量特徵，預測流量通訊內容相關的隱私信息

負載特徵流量識別

研究內容:

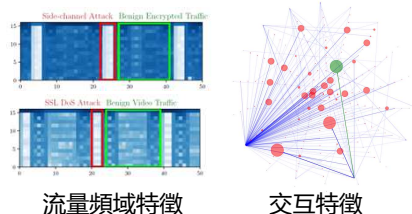
傳統NIDS
網站防火牆



統計特徵流量識別

研究內容:

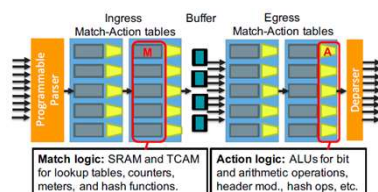
流粒度、包粒度特徵
加密流量識別



攻擊流量防禦系統

研究內容:

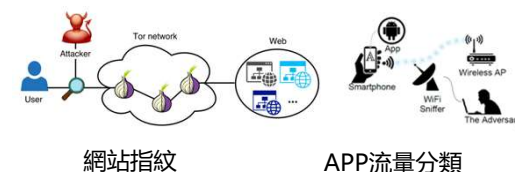
傳統匹配過濾機制
可編程數據面防禦機制



流量分析攻擊

研究內容:

網站指紋生成
其他流量分析攻擊



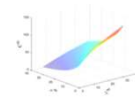
未知攻擊
高效信息使用



未知攻擊
未知流量模式



流量規模
海量流量匹配



竊取信息
高效信息使用

以流量分析系統的三要素為切入點，掌握系統化分析流量識別系統的方法



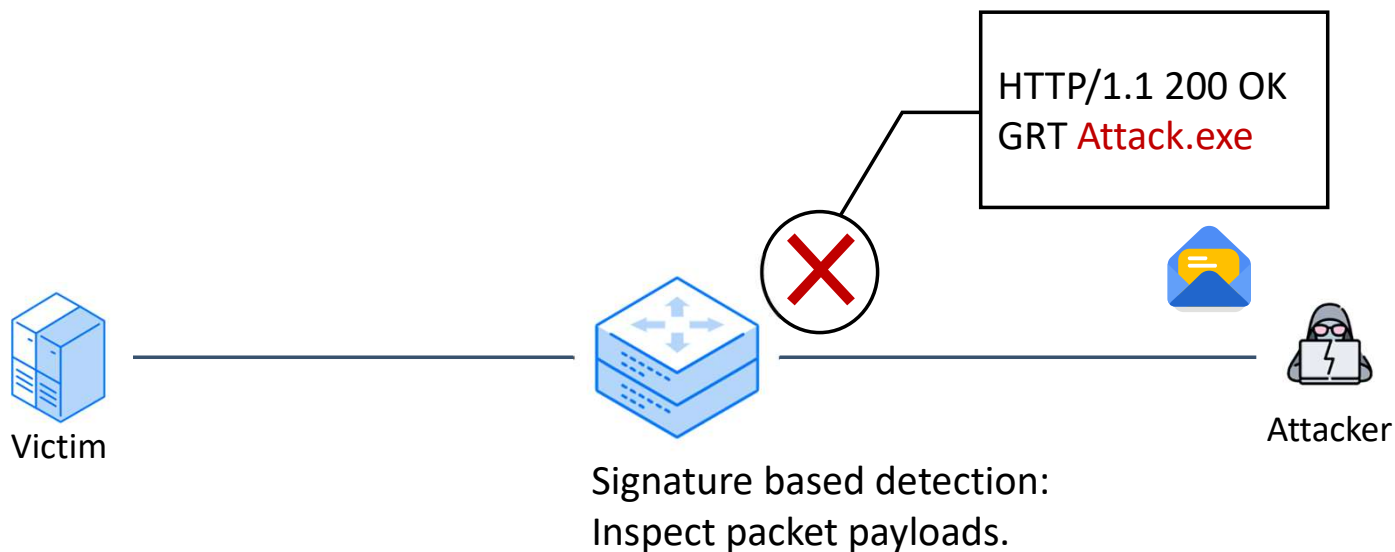
第1節 負載特徵驅動的流量檢測

- ✓ 基于數據包負載匹配的傳統檢測方法
- ✓ 基于人工智能的流量檢測方法總體框架
- ✓ 基于人工智能的負載分析方法：網站防火牆
- ✓ 基于人工智能的負載分析方法：惡意軟件檢測



傳統惡意流量識別方法：基于固定規則

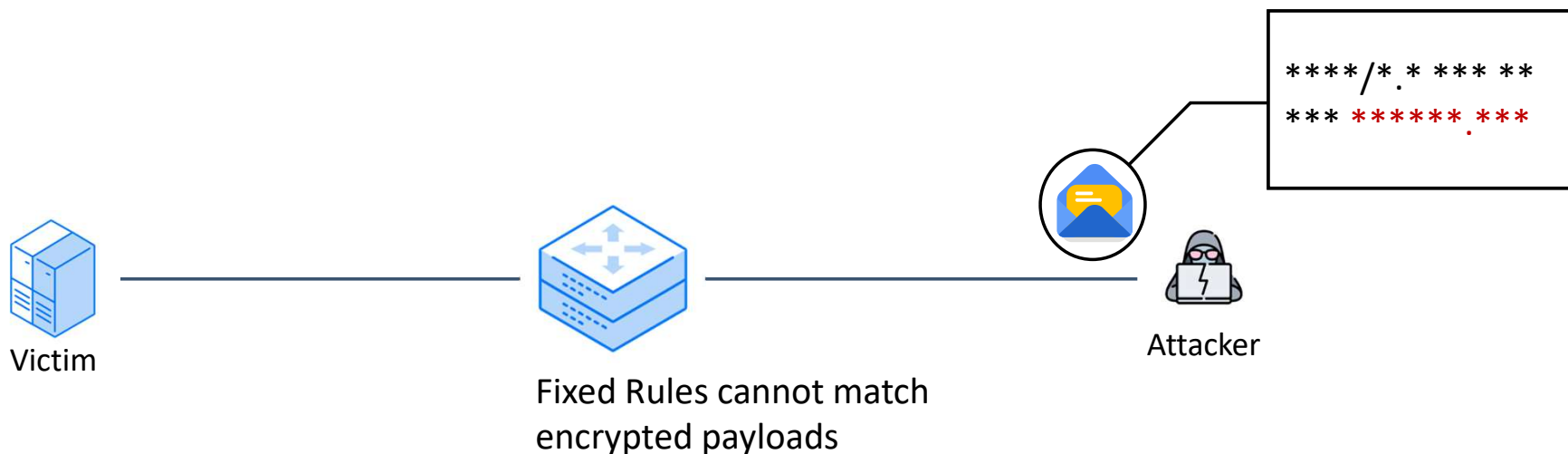
利用固定規則對流量的**負載**進行**匹配**





傳統惡意流量識別方法：基于固定規則

利用固定規則對流量的**負載**進行**匹配**





基于固定規則的惡意流量識別應用案例

以Zeek為例，現代固定規則檢測系統支持的三大類匹配方法

1. 對負載的統計特徵進行匹配

示例：監控和標記異常活躍的主機

以下是一個 Zeek 腳本示例，該腳本監控網絡連接，計算特定統計特徵，如主機的連接次數，并標記那些異常活躍的主機

- 全局變量定義

ip_connection_counts 存儲了每個 IP 地址的連接次數

- 事件處理

connection_established 事件在每個新的連接建立時觸發。腳本增加該連接源 IP 的計數，并檢查其是否超過定義的閾值，如果某個 IP 的連接次數超過閾值，系統將打印一條警告消息，并可以采取進一步的響應措施

```
# 定義一個表來存儲每個IP地址的連接計數
global ip_connection_counts: table[addr] of count = {};

# 定義閾值，超過此閾值的主機被認為是異常活躍
const threshold: count = 100;

# 當新的連接被建立時觸發此事件
event connection_established(c: connection)
{
    # 對源IP地址的連接計數加1
    ip_connection_counts[c$id$orig_h] += 1;

    # 檢查該源IP的連接次數是否超過閾值
    if (ip_connection_counts[c$id$orig_h] > threshold)
    {
        print fmt("High activity detected: %s has %d
connections", c$id$orig_h,
ip_connection_counts[c$id$orig_h]);
        # 這裏可以執行額外的響應措施，如發出警報或進一步調查
    }
}

event zeek_done()
{
    for (ip, count in ip_connection_counts)
    {
        print fmt("%s made %d total connections", ip, count);
    }
}
```



基于固定規則的惡意流量識別應用案例

以Zeek為例，現代固定規則檢測系統支持的
三大類匹配方法

2. 對包頭字段進行匹配

示例：匹配 IP 黑名單來檢測潛在的攻擊流量

在 Zeek 中使用腳本檢測來自黑名單 IP 地址的潛在攻擊流量是一種常見的網絡監控策略；這種方法通過匹配網絡流量中的 IP 地址與預定義的黑名單來識別可能的惡意活動

- **全局變量定義**

bad_ips 集合存儲了預定義的黑名單 IP 地址

- **事件處理**

connection_established 事件在每個新的連接建立時觸發。腳本檢查該連接的源 IP 是否在黑名單中，如果源 IP 地址在黑名單中，系統將打印一條警告消息，並可以根據需要採取進一步的安全措施

```
# 定義一個 IP 黑名單
global bad_ips: set[addr] = {
    192.168.1.100,
    10.0.0.5,
    172.16.4.1
};

# 當有新的連接被初始化時觸發此事件
event connection_established(c: connection)
{
    # 檢查源 IP 是否在黑名單中
    if (c$id$orig_h in bad_ips)
    {
        print fmt("Attack detected: Connection from IP %s to %s on
port %d",
                    c$id$orig_h, c$id$resp_h, c$id$resp_p);
        # 可以采取進一步的響應措施，例如斷開連接、記錄詳細信息等
    }
}

# 當 Zeek 初始化時觸發此事件，用于確認腳本已加載
event zeek_init()
{
    print "Zeek IP blacklist script loaded. Monitoring for
connections from blacklisted IPs.";
}
```



基于固定規則的惡意流量識別應用案例

以Zeek為例，現代固定規則檢測系統支持的
三大類匹配方法

3. 對明文流量負載進行匹配

示例：監控可疑 DNS 查詢

假設我們已知某些惡意域名，并希望監控網絡中對這些域名的 DNS 請求；Zeek 脚本示例定義了一個惡意域名列表，并在網絡流量中檢測到這些域名的 DNS 請求時生成一個警告

• 全局變量定義

在脚本中定義了一個 `suspicious_domains` 集合，其中包含了需要監控的惡意域名。

• 事件處理

通過 `dns_request` 事件，脚本會在每次 DNS 請求發生時被觸發；如果查詢的域名出現在我們的可疑列表中，脚本將打印一條消息，并可以執行其他的響應措施

```
# 定義一個惡意域名列表
global suspicious_domains: set[string] = {
    "malicious-example.com",
    "badguy.org"
};

# 當 Zeek 檢測到 DNS 查詢時觸發此事件
event dns_request(c: connection, msg: dns_msg, query: string)
{
    # 檢查查詢的域名是否在可疑列表中
    if (query in suspicious_domains)
    {
        print fmt("Detected suspicious DNS query for %s from %s", query, c$id$orig_h);
        # 可以添加更多的響應措施，例如記錄事件、發送警告等
    }
}

# 當 Zeek 完成脚本加載時觸發此事件
event zeek_init()
{
    print "Zeek script loaded. Monitoring suspicious DNS queries.";
}
```



基于固定規則的惡意流量識別方法小結

利用固定規則對流量的負載進行匹配

缺點1： 依賴深度包檢測技術，對加密流量不可用

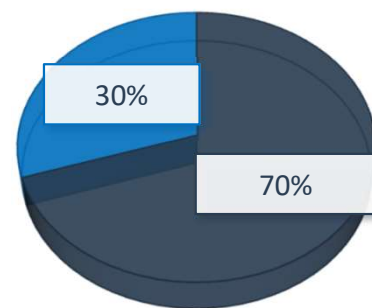
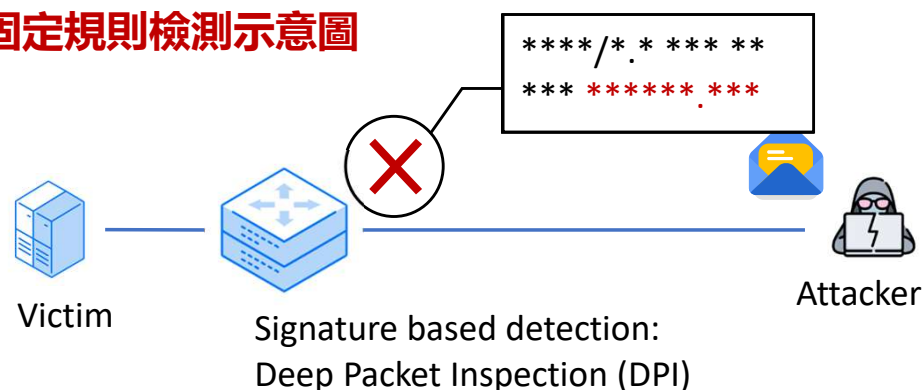
缺點2： 大量過濾規則消耗計算資源

缺點3： 逃逸策略躲避檢測

缺點4： 人工設計的固定規則僅可針對已知流量進行過濾，無法應對未知攻擊 (Zero-Day Attacks)

固定規則檢測資源開銷遠大于
檢測效果的收益

固定規則檢測示意圖



Cisco: Over **70%** attacks were constructed by encrypted attack traffic.

■ Encrypted
■ Plaintext





第2節 統計特徵驅動的流量識別方案

- ✓ 基于數據包粒度特徵的檢測方法
- ✓ 基于流粒度特徵的檢測方法
- ✓ 編程網絡設備上的攻擊流量檢測
- ✓ 加密攻擊流量檢測



基于包粒度特徵的檢測方法

■ 技術方法

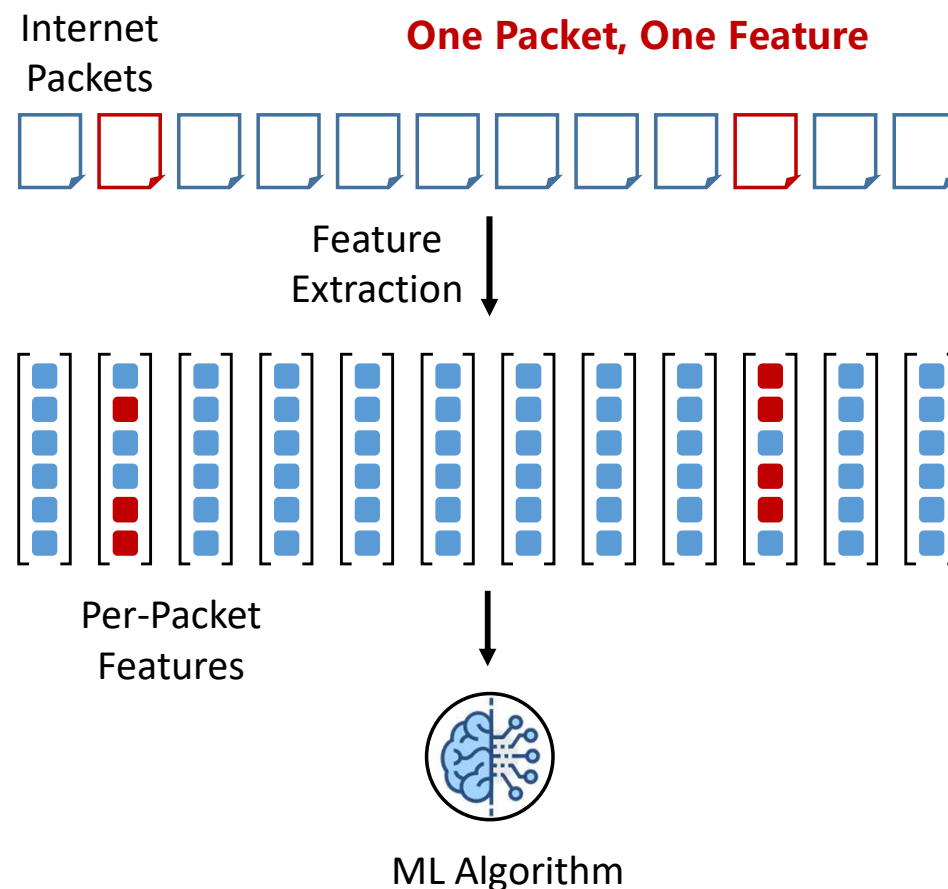
基于數據包負載內容的檢測方法

為每一個數據包抽取一個特徵向量，作為機器學習的輸入，分類每一個數據包是否為正常的數據包

■ 技術評價

優勢： 1. 不依賴數據包負載進行檢測； 2. 細粒度分析網絡流量

劣勢： 1. 逐個數據包分析的效率問題，通常離線運行或工作在低負載網絡下； 2. 魯棒性不佳，操縱數據包當中字段可以完成逃逸攻擊





基于包粒度特徵的檢測方法

■ 代表方案: Kitsune

分析目標：檢測IoT設備的各種攻擊流量，包含了洪泛攻擊、指令注入、遠程漏洞利用等等

流量特徵：從數據包頭部抽取了115個維度的特徵，包含了流級別的統計信息

分析算法：采用聚合的自編碼器，本質上是一個無監督模型用于檢測未知的攻擊策略，以115維特徵為輸入，以重構誤差為輸出

技術優勢：最早的基于特徵的無監督攻擊檢測方法是惡意流量檢測的代表性基線方案

開放了源代碼和數據集

具體采用的模型是多個自編碼器的集成模型

Kitsune方法為每一個包構建一個特徵向量，其中包含了數據流、地址等不同粒度的信息

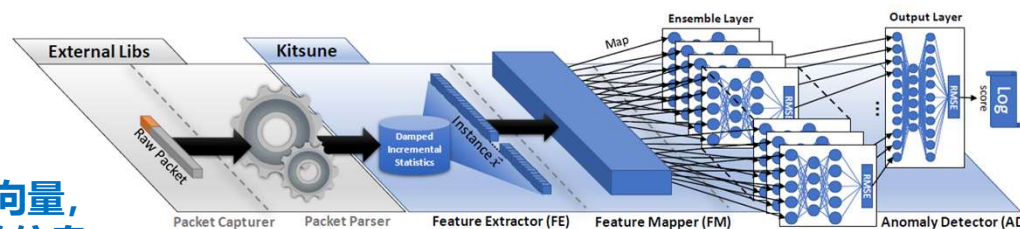


Fig. 3: An illustration of Kitsune's Architecture.

Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection, NDSS 2018.

開放討論：這類方法可能存在哪些問題



基于包粒度特徵的檢測方法

■ 代表方案: Kitsune

深入分析:

流量特徵: Kitsune抽取的流量特徵分為兩大類:

一維特徵舉例:

按照MAC地址、IP地址、IP地址對、套接字聚集的流的帶寬均值方差

二維特徵舉例:

IP地址對、套接字聚集的流的帶寬間的協方差、相關係數

計算統計量的方法：一維和二維

Type	Statistic	Notation	Calculation
1D	Weight	w	w
	Mean	μ_{S_i}	LS/w
	Std.	σ_{S_i}	$\sqrt{ SS/w - (LS/w)^2 }$
2D	Magnitude	$\ S_i, S_j\ $	$\sqrt{\mu_{S_i}^2 + \mu_{S_j}^2}$
	Radius	R_{S_i, S_j}	$\sqrt{(\sigma_{S_i}^2)^2 + (\sigma_{S_j}^2)^2}$
	Approx. Covariance	Cov_{S_i, S_j}	$\frac{SR_{ij}}{w_i + w_j}$
	Correlation Coefficient	P_{S_i, S_j}	$\frac{Cov_{S_i, S_j}}{\sigma_{S_i} \sigma_{S_j}}$

The packet's...	Statistics	Aggregated by	# Features	Description of the Statistics
...size	μ_i, σ_i	SrcMAC-IP, SrcIP, Channel, Socket	8	Bandwidth of the outbound traffic
...size	$\ S_i, S_j\ , R_{S_i, S_j}, Cov_{S_i, S_j}, P_{S_i, S_j}$	Channel, Socket	8	Bandwidth of the outbound and inbound traffic together
...count	w_i	SrcMAC-IP, SrcIP, Channel, Socket	4	Packet rate of the outbound traffic
...jitter	w_i, μ_i, σ_i	Channel	3	Inter-packet delays of the outbound traffic

Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection, NDSS 2018.

**23個特徵 * 5個滑動時間窗口
(5, 3, 1, 0.1, 0.01) = 115個特徵**



基于包粒度特征的检测方法

代表方案: nPrintML

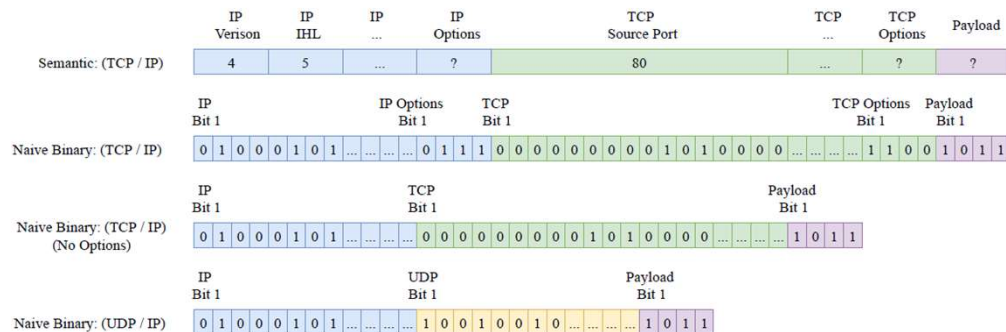
分析目標： 檢測各類網絡攻擊策略生成的流量

流量特徵： 將數據包的首部逐比特地轉化成為一個定長的 0/+1/-1的序列，其中 -1 表示對應位置的比特不存在

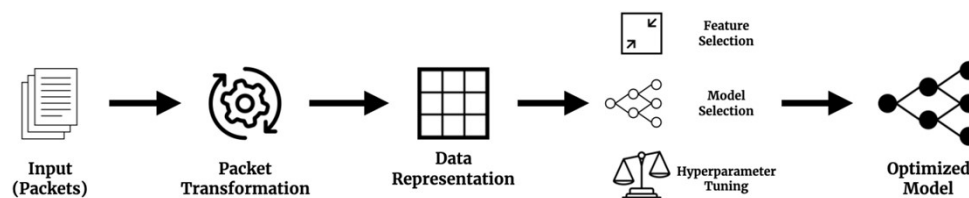
分析算法： 採用了基于統計機器學習的自動機器學習方法，自動調節機器學習參數，在驗證數據集上最大化檢測效果

技術優勢： 最早地實現了流量分析任務上的自動特徵工程，直接使用0/-1/+1序列而不用手工設計流量特徵

New Directions in Automated Traffic Analysis, ACM CCS, 2021.



nPrintML抽取數據包特徵的過程：
本質上是將數據包轉化爲一個 0/-1/+1序列的過程



系統的高層次流程圖，AutoML包含了特徵、模型、參數的選擇過程



基于包粒度特徵的檢測方法

■ 代表方案: CLAP

分析目標： 檢測嘗試繞過固定規則NIDS的網絡流量
基于固定規則的NIDS在維護流狀態上通常實現地不完備，因此可以被具備特定語義的數據包繞過

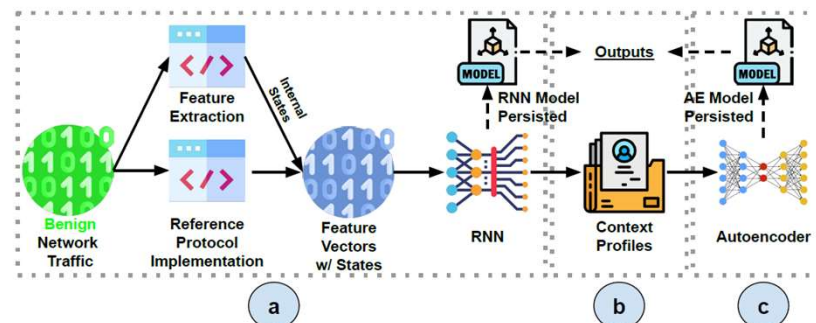
例如，SYMTCP系統發現，對於一些檢測系統，發送2個TCP RST可以誤導檢測系統相信TCP流已經終止不再對其進行檢測

流量特徵： 將數據包頭中的字段地累積量作為特徵

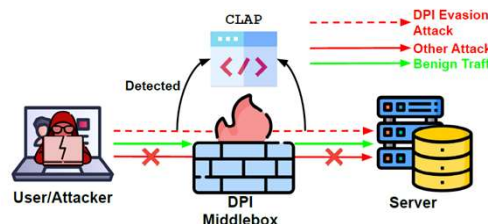
分析算法： 循環神經網絡，無監督檢測注入的惡意數據包（例如，違反協議語義的RST）

SYMTCP: Eluding Stateful Deep Packet Inspection with Automated Discrepancy Discovery, NDSS 2020.
You Do (Not) Belong Here: Detecting DPI Evasion Attacks with Context Learning, CoNEXT 2020.

技術優勢： 用循環神經網絡分析數據包交互語義，對逃逸DPI審計的流量進行識別，另一方面對狀態的維護是現有入侵檢測系統實現的重大不足



CLAP方案的高層架構設計：
用數據包當中的字段表示數據包，構造成一個序列，利用RNN分析數據的依賴關係





基于包粒度特徵的檢測方法：總結

■ 對包粒度特徵的檢測方案的評價

1. 包粒度的特徵檢測相比于與傳統負載特徵分析的優點在于：

- › 不依賴數據包負載信息：可以識別加密流量
- › 采用的統計信息可以對多種流量提取：實現通用檢測，識別多種攻擊流量
- › 不用維護流狀態：一定程度降低了檢測開銷

2. 包粒度特徵檢測仍然存在的不足：

將數據包視為孤立個體，難以分析數據包之間的高層次的依賴關係

此外，逐一分析每一個數據包帶來顯著的性能開銷，無法適應快速增長的流量規模

為解決這一問題，基于流粒度的檢測方法被大量提出于應用



第2節 統計特徵驅動的流量識別方案

- ✓ 基于數據包粒度特徵的檢測方法
- ✓ **基于流粒度特徵的檢測方法**
- ✓ 編程網絡設備上的攻擊流量檢測
- ✓ 加密攻擊流量檢測



基于流粒度特徵的檢測方法

■ 技術方法

基于流粒度特徵的檢測方法

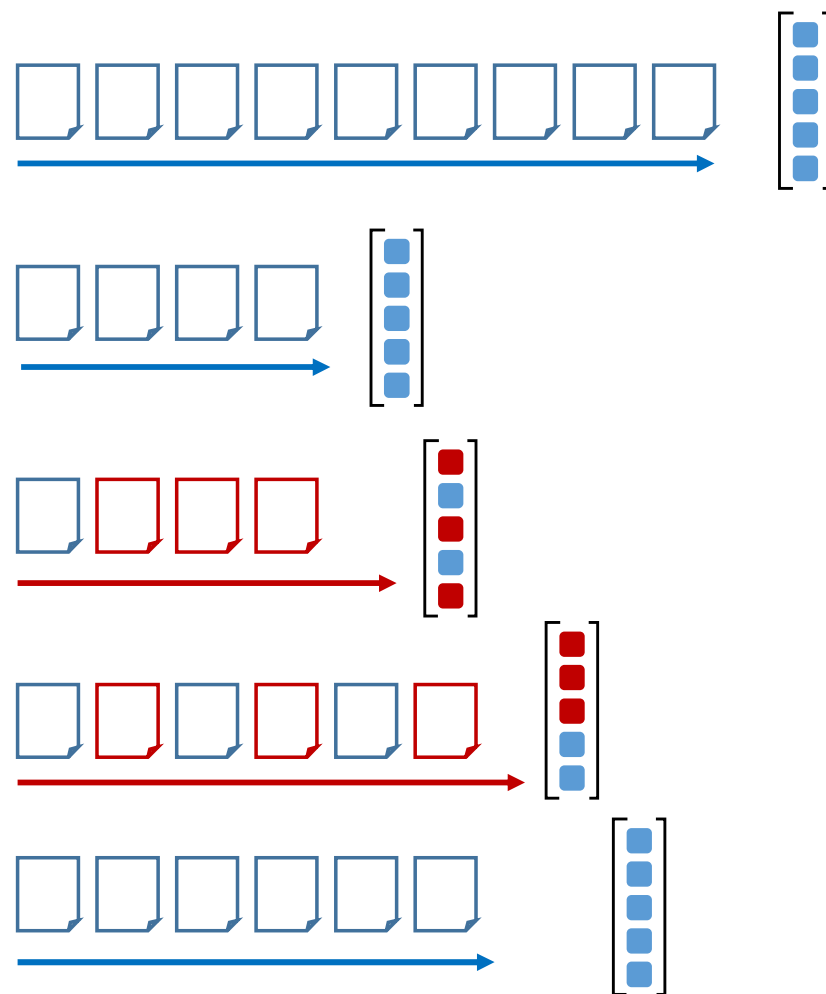
為每一條流抽取一個特徵向量，作為機器學習的輸入，
分類每一條流是否為正常的數據包

**流一般被定義為具備相同五元組的數據包序列，即具備
相同源目的地址+源目的端口+傳輸層協議類型**

■ 技術評價

優勢： 1. 可以在流的基礎上構造複雜特徵，檢測複雜攻擊；
2. 在沒有專用硬件的條件下達到良好的效率

劣勢： 1. 分析粒度比較粗糙；
2. 將數據包重組為流，
引入額外的開銷

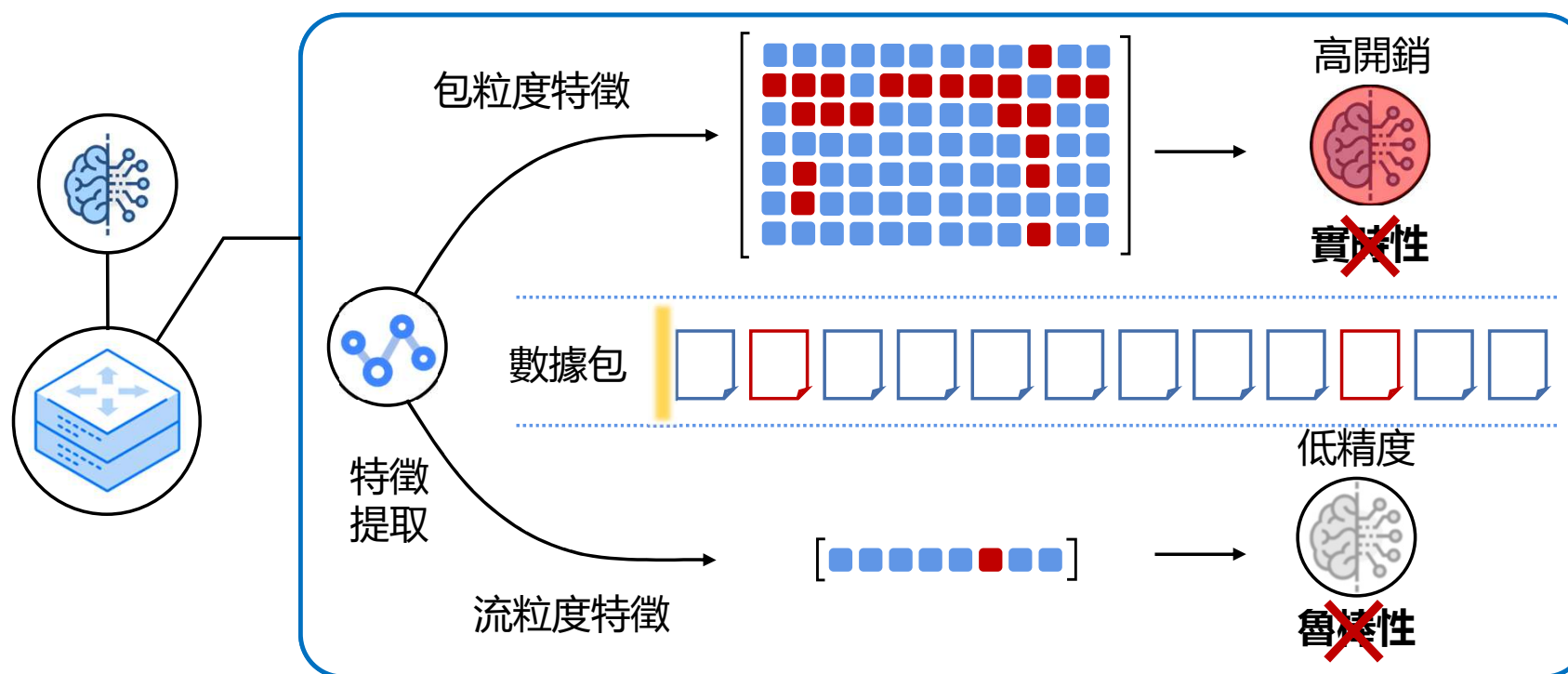




比較：基于 流粒度 / 包粒度 特徵的檢測方法

■ 包粒度特徵和流粒度特徵的比較

1. **包級粒度征的方案** 為每個數據包抽取特徵：特徵規模過大造成檢測開銷上升
2. **流級粒度征的方案** 為每條流抽取特徵：粒度過于粗糙，攻擊者很容易逃逸檢測



兩大類流量
特徵比較



基于流粒度特徵的檢測方法

■ 代表方案: DISCLOSURE

分析目標： 識別惡意軟件C2控制服務器流量，其中包含有加密通訊產生的流量

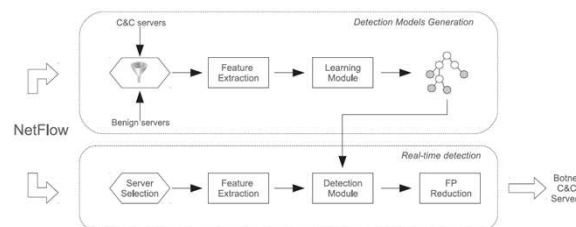
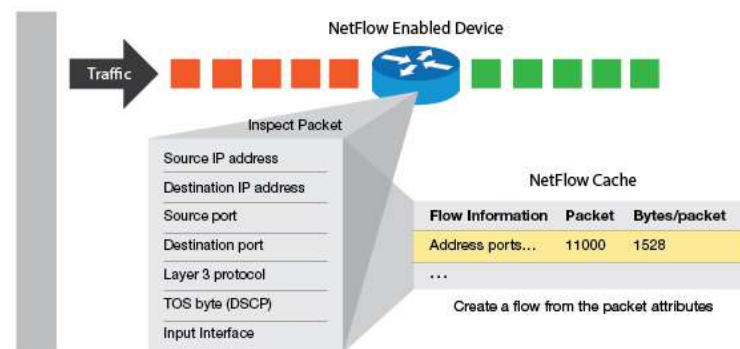
流量特徵： 從NetFlow日志當中提取的流粒度的統計信息

分析算法： 采用有監督的隨機森林算法和IP白名單降低假陽性

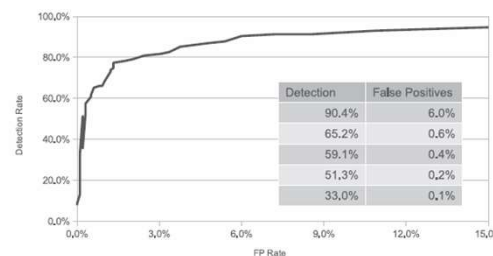
技術優勢： 相比于傳統的惡意軟件C2檢測可以識別加密信道的惡意軟件通訊流量

此外，NetFlow被大多數商用交換機支持，可以被部署在高帶寬場景下

DISCLOSURE: Detecting Botnet Command and Control Servers Through Large-Scale NetFlow Analysis, ACM ACSAC, 2012.



DISCLOSURE的高層架構設計：有監督模型學習NetFlow當中的數據



檢測效果：
AUROC 曲線顯示，系統在較低誤報的前提下，檢測的準確度很高



基于流粒度特徵的檢測方法

■ 代表方案: DISCLOSURE

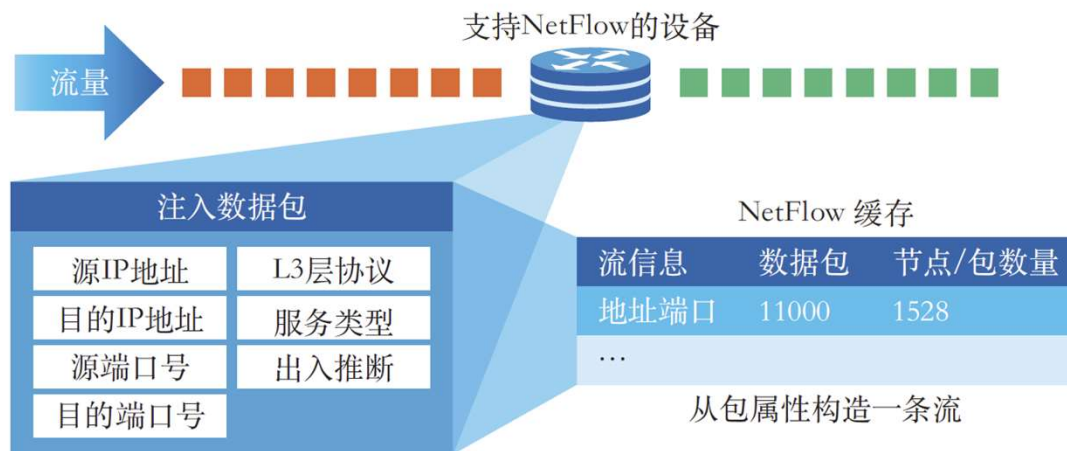
NetFlow流量日志: [RFC 3954]

NetFlow 對流的定義: 采用七元組, 即: 物理網口號, 源/目的地址, 源/目的端口, 三層協議, IP中的ToS字段

NetFlow 對統計特徵的定義: 數據包數量和總的比特數、以及流完成時間等等

NetFlow 對數據的壓縮: 定義了網路日志的壓縮和傳輸流程

NetFlow 對流的採樣: 例如在廣域網環境下通常采用1:1000進行採樣防止耗盡存儲空間



基于NetFlow的識別方案的缺陷是什麼?

DISCLOSURE: Detecting Botnet Command and Control Servers Through Large-Scale NetFlow Analysis, ACM ACSAC, 2012.



基于流粒度特徵的檢測方法

■ 代表方案: BotFinder

分析目標：識別惡意軟件C2控制服務器流量，其中大部分的通訊流量是加密的

流量特徵：抽取了五個特徵，例如單位時間內傳輸的比特數量，和通訊的頻率等特徵

分析算法：利用無監督的聚類算法應對未知流量樣本；同時啓用IP白名單降低假陽性

方案優勢：傳統檢測惡意軟件流量需要使用**深度包檢測**，無法應對加密惡意軟件流量，例如之前介紹的Nazca

BotFinder: Finding Bots in Network Traffic Without Deep Packet Inspection, ACM CoNEXT, 2012

作者通過測量發現了惡意軟件分發流量在時空特徵上存在顯著的特性

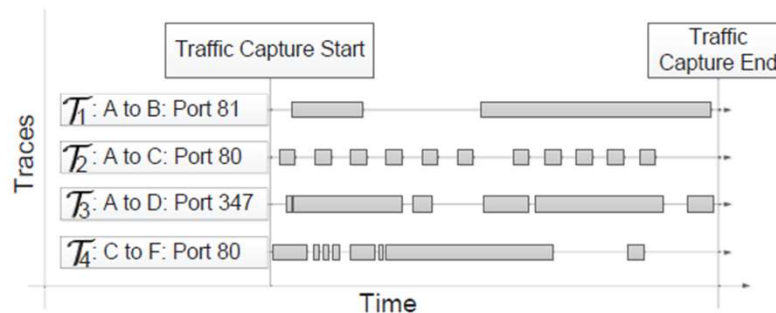


Table 3: Detection rate and false positive results of BOTFINDER (acceptance threshold $\alpha=1.8$) in the cross-validation experiment and compared to BotHunter.

Malware Family	BOTFINDER Detection	BOTFINDER False Positives	BotHunter Detection
Banbra	100%	0	24%
Bifrose	49%	0	0%
Blackenergy	85%	2	21%
Dedler	63%	0	n/a
Pushdo	81%	0	11%
Sasfis	87%	1	0%

在真實世界環境當可以有效地檢測出各種惡意軟件下載地流量



基于流粒度特徵的檢測方法

■ 代表方案: Whisper

分析目標：傳統方法的流量特徵，通常采用統計特徵，例如單位時間內數據包的數量

雖然能保證實時檢測，但是這些特徵過于粗糙，容易被攻擊者逃逸

而包粒度的檢測無法保證實時性，是否存在流特徵包特徵之間的折衷方案

Table 1: Comparing the Existing Malicious Traffic Detection Methods

Category of Detection Systems		Feature Extraction Methods	Zero-Day Detection	High Accuracy	Robust Detection	Realtime Detection	High Throughput	Task Agnostic
Rule based		Preconfigured fix rules [6, 29, 35]	×	✓	×	✓	✓	×
ML based	Packet-level	Packet header fields [53]	✓	✓	×	✓	×	✓
		Context statistics [42]	✓	✓	×	✓	×	✓
		Payload statistics [68]	✓	✓	×	×	×	✓
	Flow-level	Flow-level statistics [5, 37, 77]	✓	×	×	×	✓	×
		Application usage statistics [4, 28, 49]	✓	✓	×	×	×	×
		Frequency domain features, Whisper	✓	✓	✓	✓	✓	✓

¹ Bartos *et al.* [4] only considered evasion strategies for malicious Web traffic.

現有方案設計目標比較

Realtime Robust Malicious Traffic Detection via Frequency Domain Analysis, ACM CCS, 2021.



流/包粒度特徵：魯棒性實時性不可兼得

■ 現有檢測方法無法兼顧 魯棒性 和 實時性

➤ 采用流粒度特徵的代表性方案：

[NDSS'21] FlowLens 方案抽取流分布特徵，可被**注入數據包操縱**

[Security'23] NetBeacon 方案在可編程交換機上抽取特徵，可通過**增刪負載操縱**

[CCS'18] DeepLog 方案采用粗粒度網路日志特徵，可被**延長連接時長操縱**

[NSDI'22] N³IC 方案采用主機級別和流級別特徵，可通過**修改發送速率操縱**

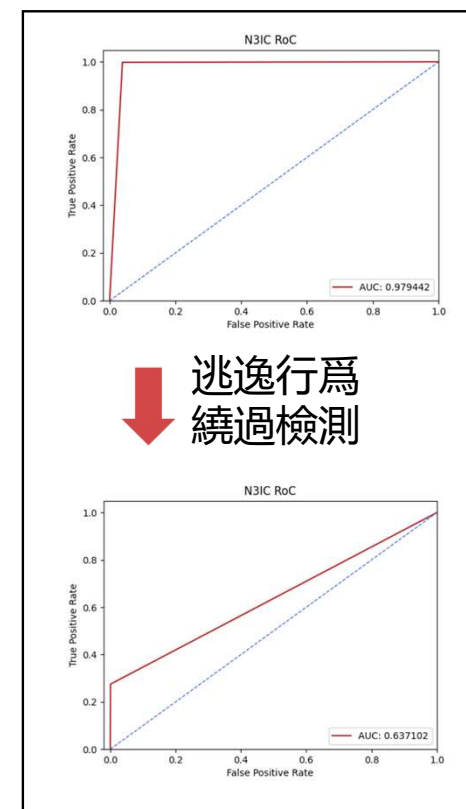
➤ 采用包粒度特徵的代表性方案：

[NDSS'18] Kitsune 方案為每個包抽取特徵，可通過直接**篡改包頭操縱**

[CCS'21] nPrintML 方案把全部包頭輸入智能算法，可通過**翻轉比特操縱**

[CoNEXT'20] CLAP方案抽取包頭字段檢測攻擊，檢測**效率低下**

這些方案未考慮攻擊者的逃逸行為，
我們的實驗表明簡單混雜正常流量可使精度下降約**30%**





流/包粒度特徵：魯棒性實時性不可兼得

■ 現有檢測方法無法兼顧 魯棒性 和 實時性

Method	Feature	Realtime	Robust
Kitsune	Packet-Level	✗	✗
FlowLens	Flow-Level	✓	✗
Jagen	Host-Level	✓	✗
N3IC	Flow&Host-Level	✓	✗
DeepLog	Flow-Level	✗	✗
NetBeacon	Flow-Level	✓	✗
Disclosure	Flow-Level	✓	✗
Nazca	Application-Level	✗	✗
ZeroWall	Application-Level	✗	✗
Xatu	Flow&Host-Level	✗	✗
Lumen	FlowLevel	✗	✗

Method	Feature	Realtime	Robust
BotFinder	Flow-Level	✗	✗
Dodia et. al.	Flow&Host-Level	✗	✓
Bartos et. al.	Flow&Application	✗	✓
ODDS	Application-Level	✗	✗
CLAP	Packet-Level	✗	✓
IXPScrubber	Flow-Level	✗	✗
nPrintML	Packet-Level	✗	✗
EULER	Application-Level	✓	✗
Taurus	Packet-Level	✓	✗
CICFlowM*	Flow-Level	✓	✗
Whisper	Frequency	✓	✓

近十年流量識別方法的魯棒性和實時性比較



基于流粒度特征的检测方法

■ 問題：如何流量識別的魯棒性和實時性

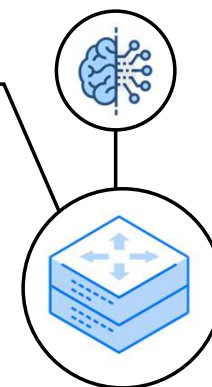
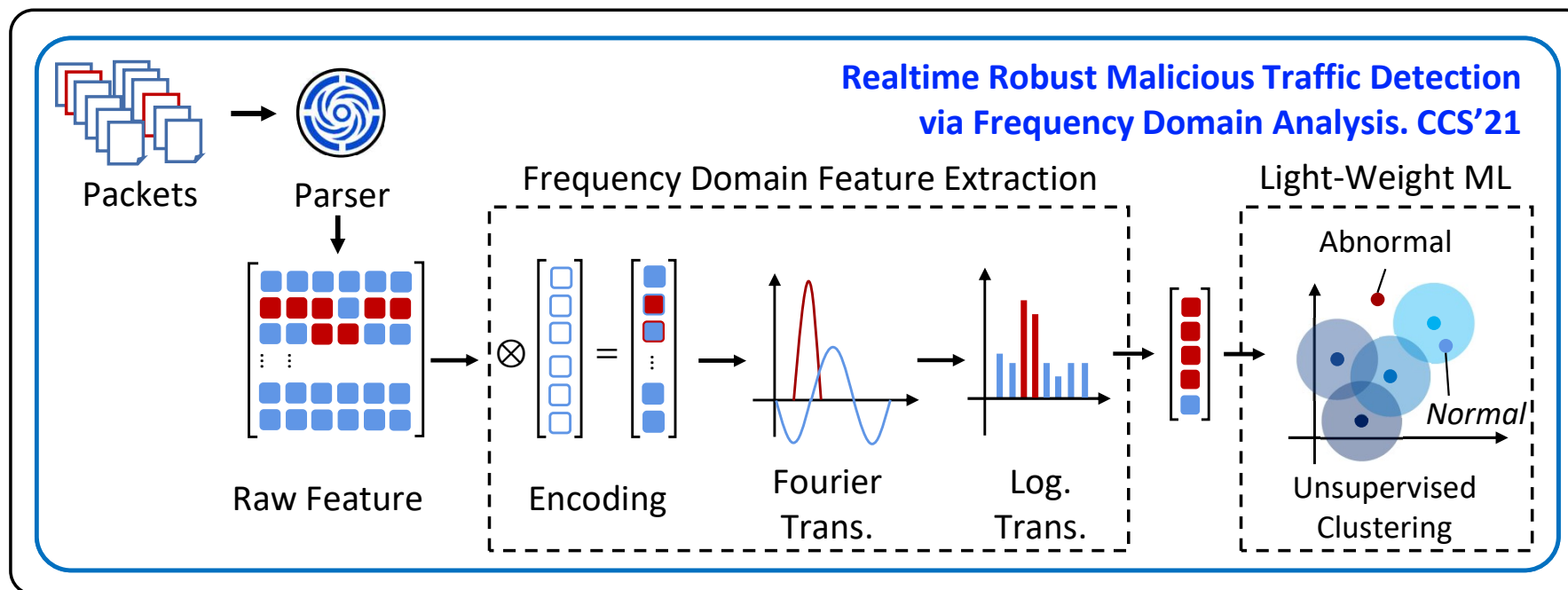
- 攻擊者逃逸的原因在于：現有流量特徵無法有效表示細粒度的數據包時序特徵

■ 流量特徵和分析算法：

- 設計流量的頻域特徵，在頻域抽取精簡的數據包時序特徵，實現防止逃逸同時滿足效率要求



ACM CCS
2021





基于流粒度特徵的檢測方法

■ 代表方案：Xatu

分析目標：在廣域網環境下識別分布式拒絕服務攻擊 (DDoS Attacks) 生成的流量

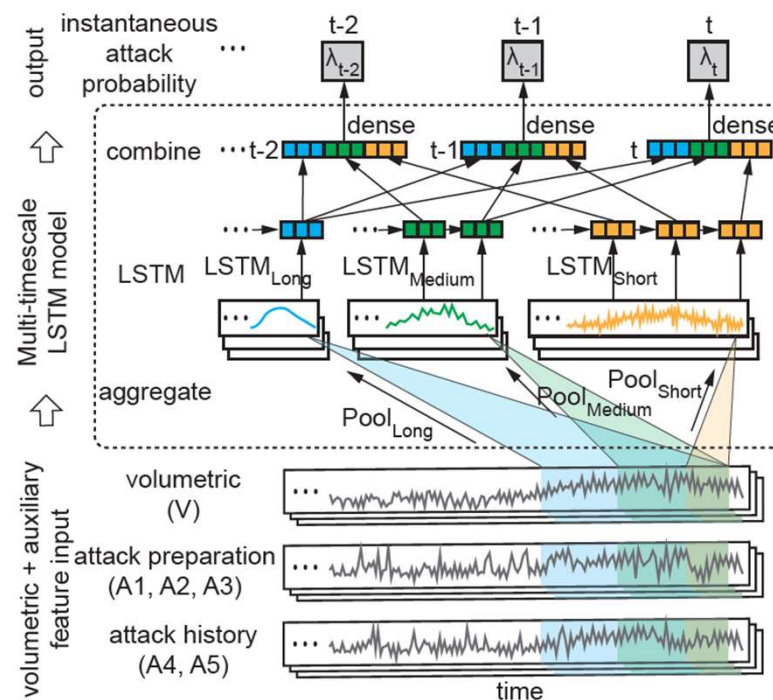
流量特徵：抽取了五個特徵的長期歷史統計信息，包含了各種粗粒度的流量的帶寬統計

分析算法：利用LSTM循環神經網絡分析歷史統計信息的序列，將偏離歷史信息的序列標記為異常

方案優勢：與傳統方法不同，利用長期的歷史信息顯著提升在知識有限的場景下對DDoS流量進行識別
這啟發我們關注歷史信息對流量分析任務具有重大作用和意義

Xatu: Boosting Existing DDoS Detection Systems Using Auxiliary Signals, ACM CoNEXT, 2022.

Xatu方案采用歷史信息檢測DDoS流量



將各類歷史統計量輸入循環神經網絡



基于流粒度特徵的檢測方法

■ 代表方案：Lumen

分析目標： 在IoT低帶寬場景下，實現通用的攻擊流量識別，即涵蓋各種針對IoT網絡，例如智能家居場景的網絡攻擊

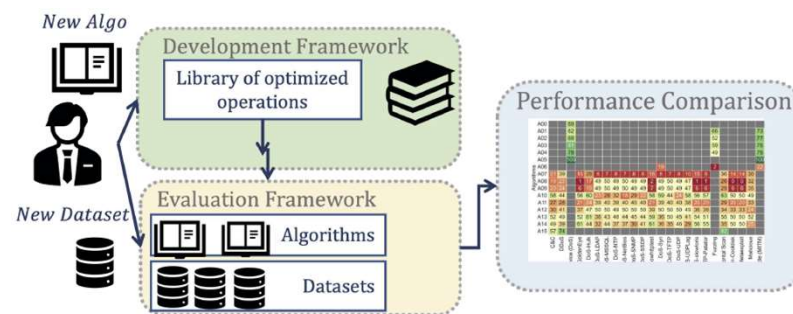
流量特徵： 綜合提取各個特徵集當中的特徵，包含了各種流級別的統計信息

分析算法： 采用集成學習方法，從現有的各類IoT流量識別方法中選擇最優的方法

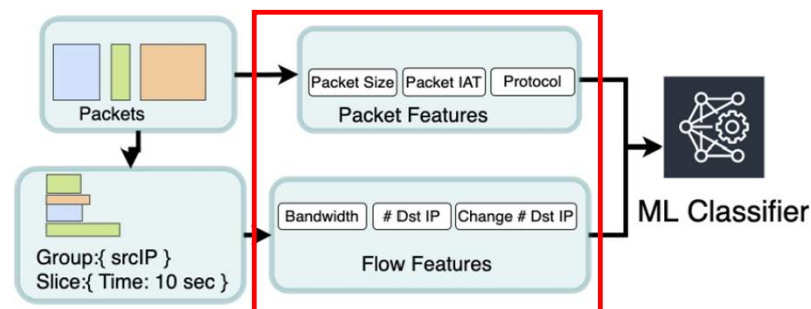
方案優勢： 集成各類IoT流量分析算法和特徵，在該任務上達到最佳準確度的效果

Lumen: A Framework for Developing and Evaluating ML-Based IoT Network Anomaly Detection, ACM CoNEXT, 2022.

Lumen總體框架，包含了特徵算法基礎原語和方案集成模塊



抽取各類流級別信息



方法核心設計理念在于綜合一切可用的特徵和算法



基于流粒度特徵的檢測方法：總結

■ 對流粒度特徵的檢測方案的評價

流級別特徵是最常見的一類特徵，因為有較高的效率被廣泛采用

1. 相比于包粒度特徵的優勢：

相比包級別特徵考慮了數據包之間的關聯關係，因而可以檢測出更加複雜的攻擊
此外解決了性能開銷的問題，距離大規模部署更近了一步

2. 相比于包粒度檢測的劣勢：

缺乏細粒度的分析，大量維護大量流特徵造成顯著的性能開銷

3. 兩大類特殊的流粒度檢測方法：

對加密惡意流量的檢測方法
可編程數據平面上的檢測方法

大約在五年前，研究人員開始思考：
既然流粒度特徵分析方法可拓展性良好
能否在Tb/s的高速網絡環境下實現流量分析



第2節 統計特徵驅動的流量識別方案

- ✓ 基于數據包粒度特徵的檢測方法
- ✓ 基于流粒度特徵的檢測方法
- ✓ **可編程網絡設備上的攻擊流量檢測**
- ✓ 加密攻擊流量檢測



可編程網絡設備上的流量檢測：可編程交換機

■ 技術目標

在綫速TB/s的高帶寬網絡環境下，實現對每一個數據包的可編程處理邏輯，相比于固定功能的傳統轉發芯片，能否實現靈活的交換功能

■ 技術思路

PISA 架構：將芯片電路分為如下幾個部分

Parser單元：實現自定義的數據包解析邏輯

Match單元：實現對包內特定信息進行內存查表

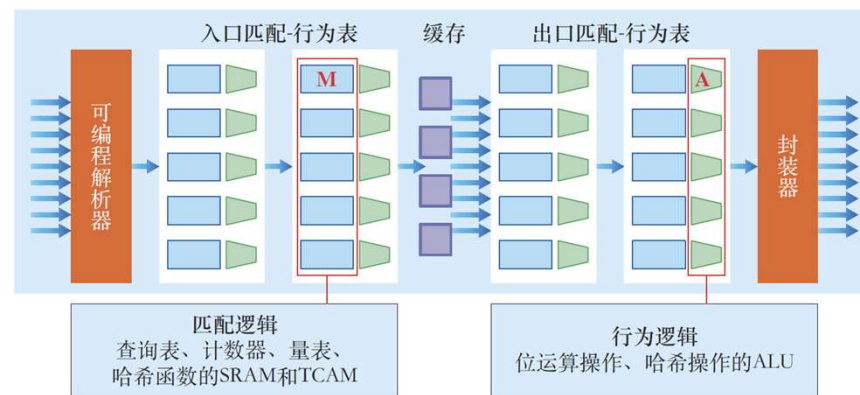
Action單元：實現對包頭的操作或簡單計算

Deparser單元：實現對數據包的重組

注意其中每一個Match-Action的組合被稱為一個Stage

其中的Match模塊和Action模塊是高度可重定義的，輔助實現動態網絡任務，例如負載均衡等

可編程交換機的編程邏輯模型PISA



**APS Network 的可編程交換機產品
支持6.4Tb/s的交換容量**



可編程網絡設備上的流量檢測：可編程交換機

■ 技術應用于流量分析

將流級別特徵抽取或者機器學習算法全部或者部分的實現
在可編程交換機上，例如Intel Tofino芯片，他們采用P4語言進行編程，可以達到Tb級別的綫速檢測

這些方法分爲純粹數據面方法，和數據面控制面混合方法

■ 技術評價

優勢： 1. 高吞吐低延遲，向著真實世界可用邁了一大步；
2. 在高吞吐網絡，例如廣域網上完成檢測，因此可以保護大量的合法用戶

劣勢： 1. 硬件資源限制導致可以實現的模型和特徵十分有限，檢測精度也存在折損

可編程網絡設備資源有限

Parameter	Intel Tofino 1 (up to 6.4 Tb)	Intel Tofino 2 (up to 12.8 Tb)
Process	16 nm	7 nm
Num of MAU stages/pipe	12	20
Total SRAM/pipe	120 Mb	200 Mb
Total TCAM/pipe	6.2 Mb	10.3 Mb
Scheduler	1-level	2-level
Number of queues/port	32/100 Gb port	Up to 128/400 Gb port
CPU port queues	32	Up to 128
Maximum SerDes speed	25 Gbps	56 Gbps
Port speeds supported	100 Gb/50 Gb/40 Gb/ 25 Gb/10 Gb	400 Gb/200 Gb/100 Gb/ 50 Gb/40 Gb/25 Gb/10 Gb
Maximum port contexts	256	256



Intel® Tofino™ 2

The next generation of programmable Ethernet switch, Intel® Tofino™ 2 is the best choice for meeting the needs of hyperscale data centers.

Built with the same architecture as Intel® Tofino™, it's capable of delivering twice the bandwidth of its predecessor—up to 12.8 Tb/s.



可編程網絡設備上的流量檢測：可編程交換機

代表方案: FlowLens

分析目標： 在高帶寬網絡環境下，識別各種惡意應用的流量，進而攔截攻擊流量

流量特徵： 借助可編程交換機提取每一條流中的包級別信息，例如長度和到達時間間隔構成的離散直方圖

分析算法： 采用有監督的決策樹模型進行分析

技術優勢： 采用直方圖表示流量特徵本質上降低了數值的範圍，以適應計算資源有限的可編程交換機。但是其缺點在于，對於機器學習算法，仍然無法在交換芯片上運行。

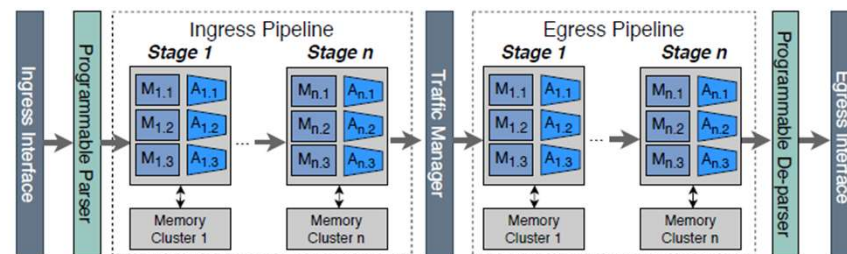
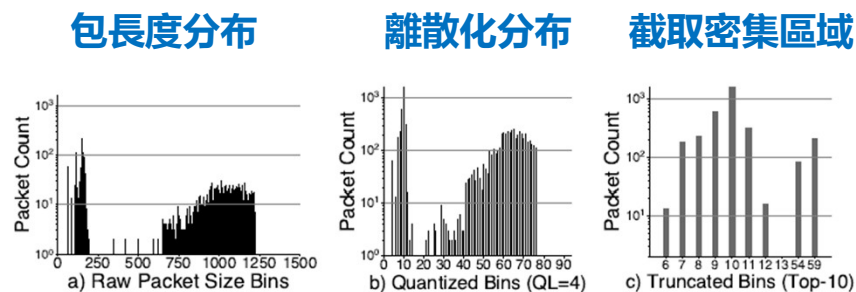


Figure 2. Protocol Independent Switch Architecture (PISA).

對於流當中的包級別特徵進行離散化可以顯著降低存儲開銷，節約芯片SRAM資源

FlowLens: Enabling Efficient Flow Classification for ML-based Network Security Applications, ISOC NDSS, 2020.



可編程網絡設備上的流量檢測：可編程交換機

■ 代表方案: HorusEye

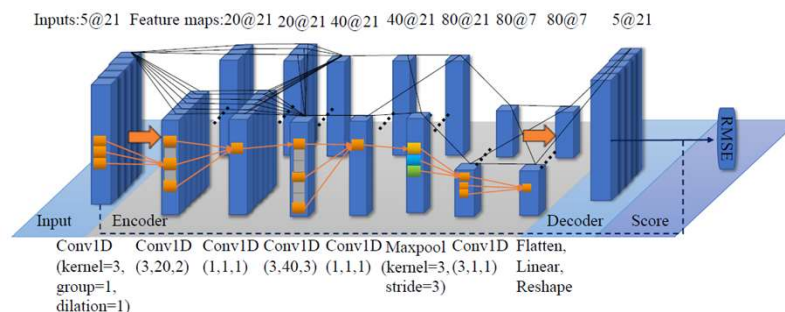
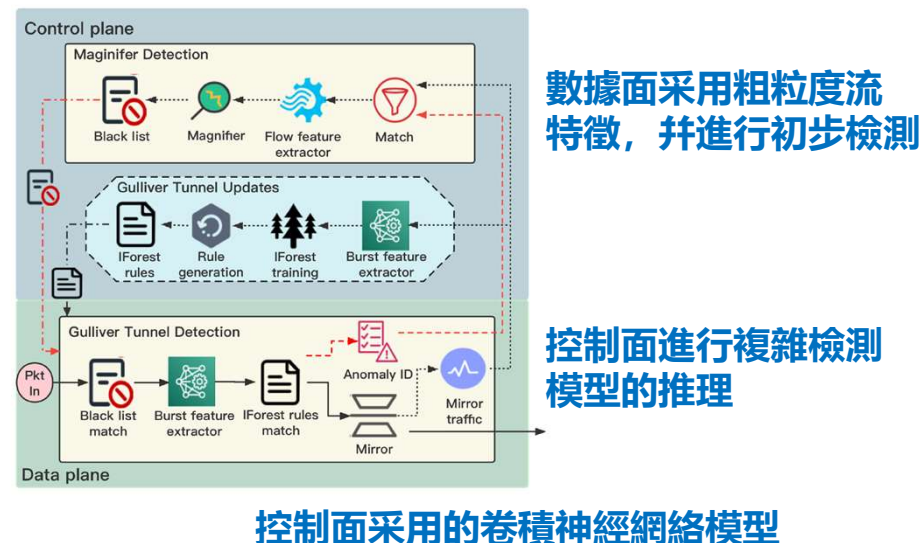
分析目標： 在高帶寬網絡環境下，識別面向IoT網絡的攻擊流量

流量特徵： 借助可編程交換機，提取每一條流的猝發傳遞特徵，例如是否存在在0.1秒傳輸超過1KB

分析算法： 對簡單樣本運行無監督的孤立森林算法，對複雜樣本運行複雜的CNN算法進行檢測

技術優勢： 將不易區分的流量放到CPU上進行檢測
在CPU上運行基于CNN的模型檢測，將易于檢測的流量在可編程交換芯片上完成檢測

HorusEye: A Realtime IoT Malicious Traffic Detection Framework using Programmable Switches, USENIX Security, 2023.



這些方法將模型部分或全部部署在CPU上
如何將模型部署在交換芯片實現TB級分析？



可編程網絡設備上的流量檢測：可編程交換機

■ 代表方案: NetBeacon

分析目標： 在高帶寬網絡環境下，完成通用的網絡的攻擊流量識別任務，同時保證極低的檢測延遲

流量特徵： 借助可編程交換機，提取每一條流的粗粒度統計信息

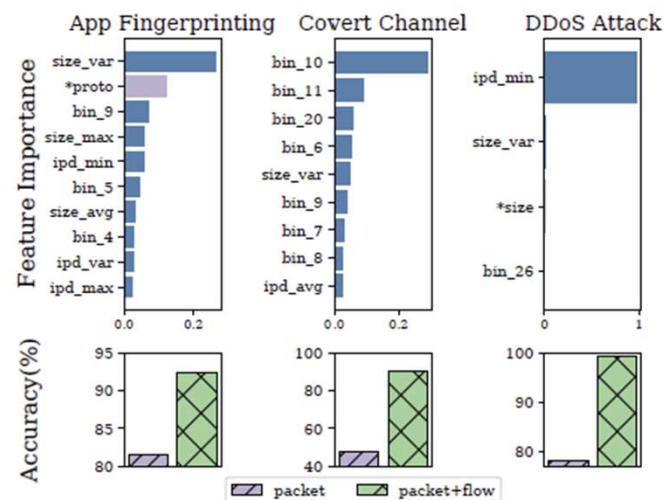
分析算法： 同時在數據平面上，完成對每一個特徵向量的決策樹推理

技術優勢： 最早的可以部署到可編程交換機的智能流量分析系統，同時支持在可編程交換機上實現複雜的特徵抽取操作，例如，方差信息等等

An Efficient Design of Intelligent Network Data Plane, USENIX Security, 2023.

方案細節： 如何采用Match-Action結構操作高效計算均值方差等**複雜特徵：**

將除法運算、平方運算轉化成爲查表問題，即在Match階段對計算結果進行直接查表，而無需在Action階段進行複雜操作和不支持的操作



複雜特徵對提升檢測性能效果顯著



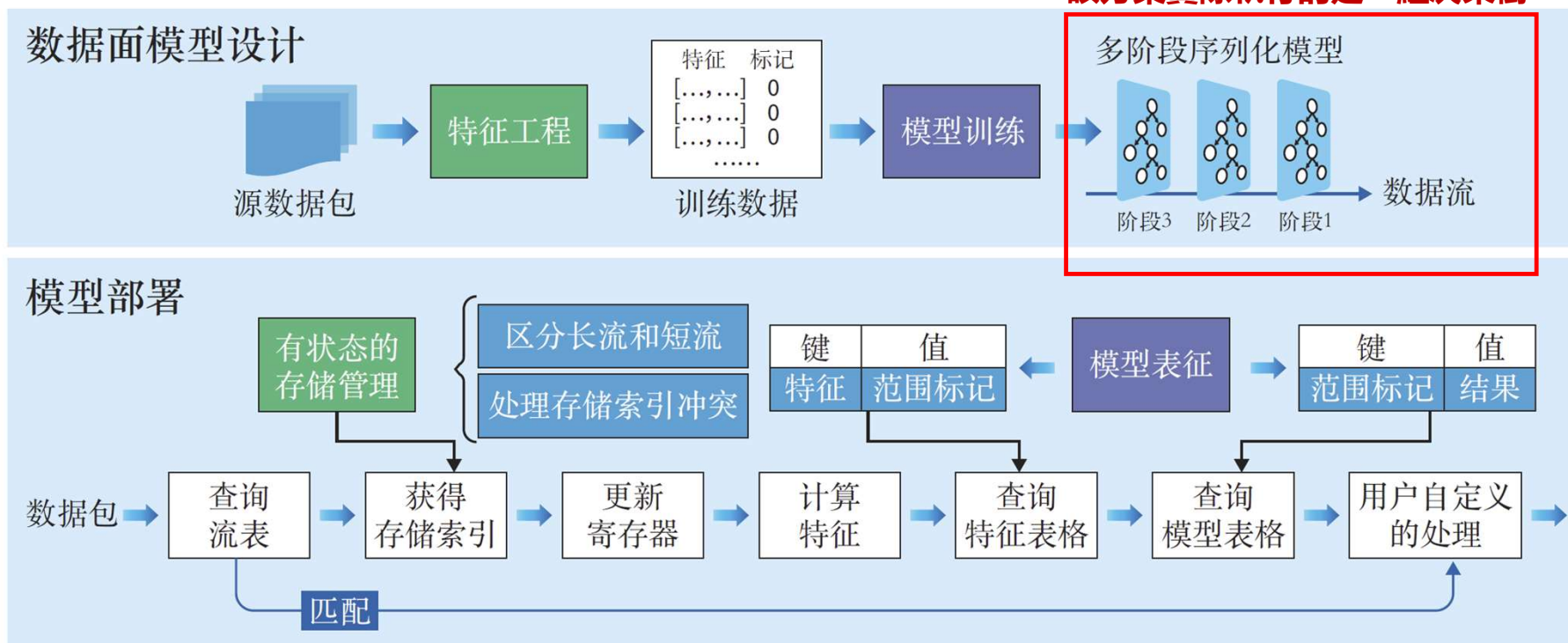
可編程網絡設備上的流量檢測：可編程交換機

■ 代表方案: NetBeacon

方案細節：應當在網絡流進行的什麼階段啟動決策樹推理？

方案提出了序列化決策樹，在流傳遞的過程當中（例如第5、10、15個數據包）時進行多次推斷

該方案實際執行的是一組決策樹





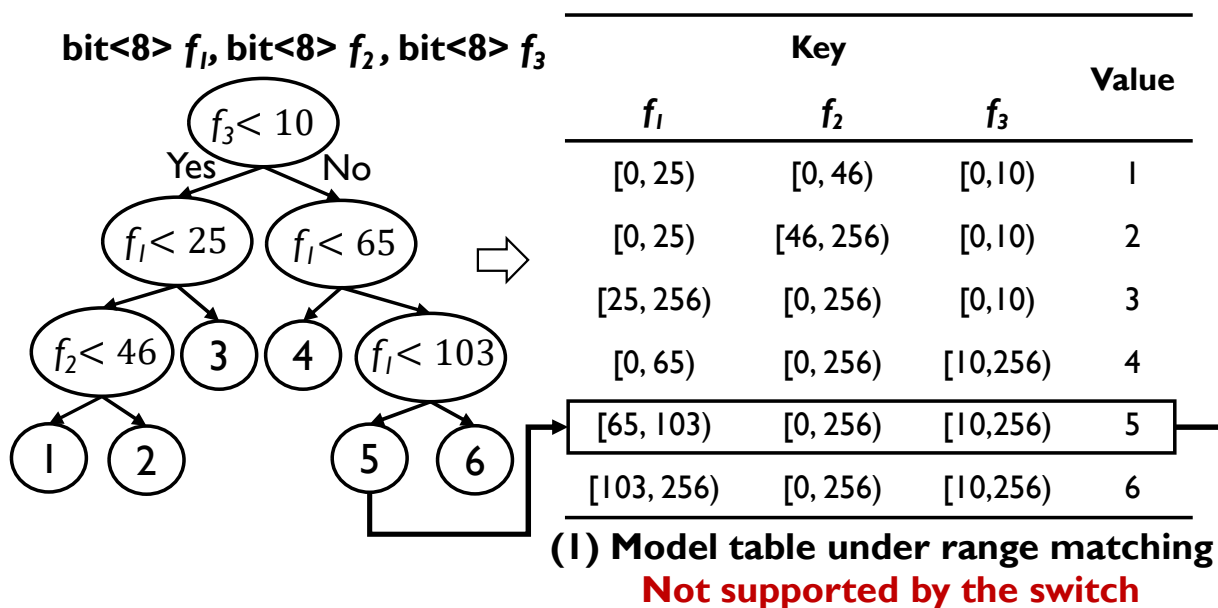
可編程網絡設備上的流量檢測：可編程交換機

■ 代表方案: NetBeacon

方案細節：如何采用Match-Action操作高效實現決策樹：

方案將決策樹進行範圍表示，最終將決策樹推斷轉換為區間匹配問題

決策樹的優勢在於很易被查表實現，而交換芯片中存在告訴查表電路支持



Key			Value
f_1	f_2	f_3	
...	...	...	...
01000001	[65,66)		
0100001*	[66,68)	0000101*	[10,12)
010001**	[68,72)	000011**	[12,16)
01001***	[72,80)	0001****	[16,32)
0101****	[80,96)	001****	[32,64)
011000**	[96,100)	01*****	[64,128)
0110010*	[100,102)	1*****	[128,256)
01100110	[102,103)		
...	...	...	...

(2) Model table under ternary matching
Combinatorial explosion of entries



可編程網絡設備上的流量檢測：智能網卡

■ 技術目標

智能網卡（Smart NIC）在網卡芯片組當中集成通用處理器，這樣以來不需要進行IO操作消耗CPU資源即可在網卡上完成簡單的包處理邏輯

■ 技術比較

智能網卡相比于可編程交換機：

可編程能力更强，因為引入了通用處理器

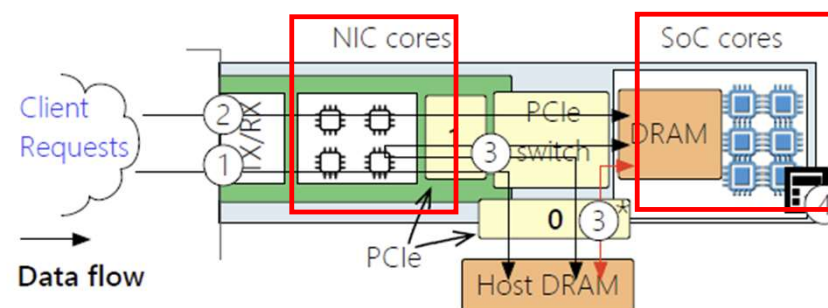
但處理吞吐量更低，這也是由于通用處理器進行的操作要比Match-Action要複雜很多

智能網卡的出現使得更加複雜的流量分析方案可以被運行在高帶寬網絡環境下

NVIDIA 的BlueField智能網卡產品



智能網卡上包含了獨立的計算資源和存儲資源





可編程網絡設備上的流量檢測：智能網卡

■ 代表方案: NIC

分析目標： 在高帶寬網絡環境下，完成通用的網絡的攻擊流量識別任務，同時保證不消耗CPU資源

流量特徵： 借助智能網卡，為每一個數據包抽取流粒度和包粒度的統計信息

分析算法： 在智能網卡上實現二值化的神經網絡，在較低的性能開銷下完成網絡的推理

技術優勢： 最早的可部署到智能網卡上的流量分析方案，借助智能網卡更加靈活的可編程能力，實現準確度更高的識別

但將浮點數形式的神經網絡轉化為二值化存在精度損失

Re-architecting Traffic Analysis with Neural Network Interface Cards, USENIX NSDI, 2022.

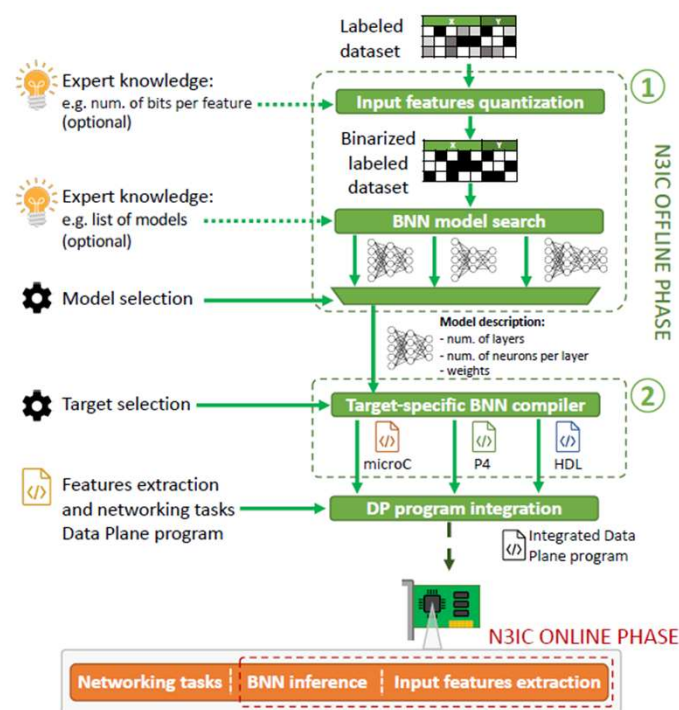


Figure 1: N3IC overview. Users provide a labeled dataset. N3IC uses it to generate a binary neural network model, which is then compiled to a data plane program for a target NIC.



可編程網絡設備上的流量檢測：總結

■ 對可編程網絡設備上的檢測方案的評價

可編程網絡設備上檢測方法最大優勢是：

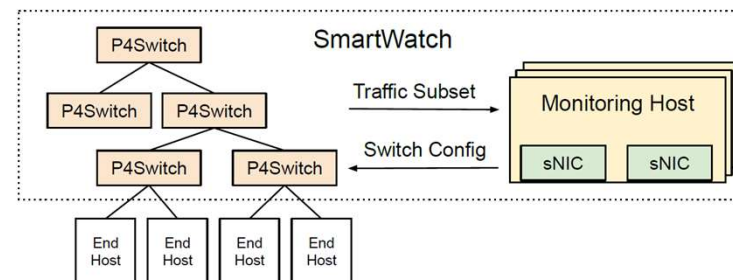
能在高吞吐網絡下實現實時檢測

然而，其支持的模型和特徵仍然十分有限：

- 1. 模型局限性：**能在數據面部署的模型大多是樹相關的模型，因為其很方便采用查表實現，雖然現有工作在嘗試部署複雜模型
- 2. 特徵局限性：**能提取的特徵相對簡單，雖然其中已經設計了大量的近似計算

SmartWatch: Accurate Traffic Analysis and Flow-state Tracking for Intrusion Prevention using SmartNICs, ACM, CoNEXT, 2021.

請注意，智能數據面的實現并非只有可編程交換機和智能網卡，例如，SmartWatch通過多種數據面實現，更加靈活的計算維護複雜特徵，還有基于FPGA的方法，例如，Taurus等方案



SmartWatch的混合式檢測架構：包含多種設備

智能數據面上的流量識別也成了近期網絡領域和安全領域研究的熱門話題



第2節 統計特徵驅動的流量識別方案

- ✓ 基于數據包粒度特徵的檢測方法
- ✓ 基于流粒度特徵的檢測方法
- ✓ 可編程網絡設備上的攻擊流量檢測
- ✓ **加密攻擊流量檢測**

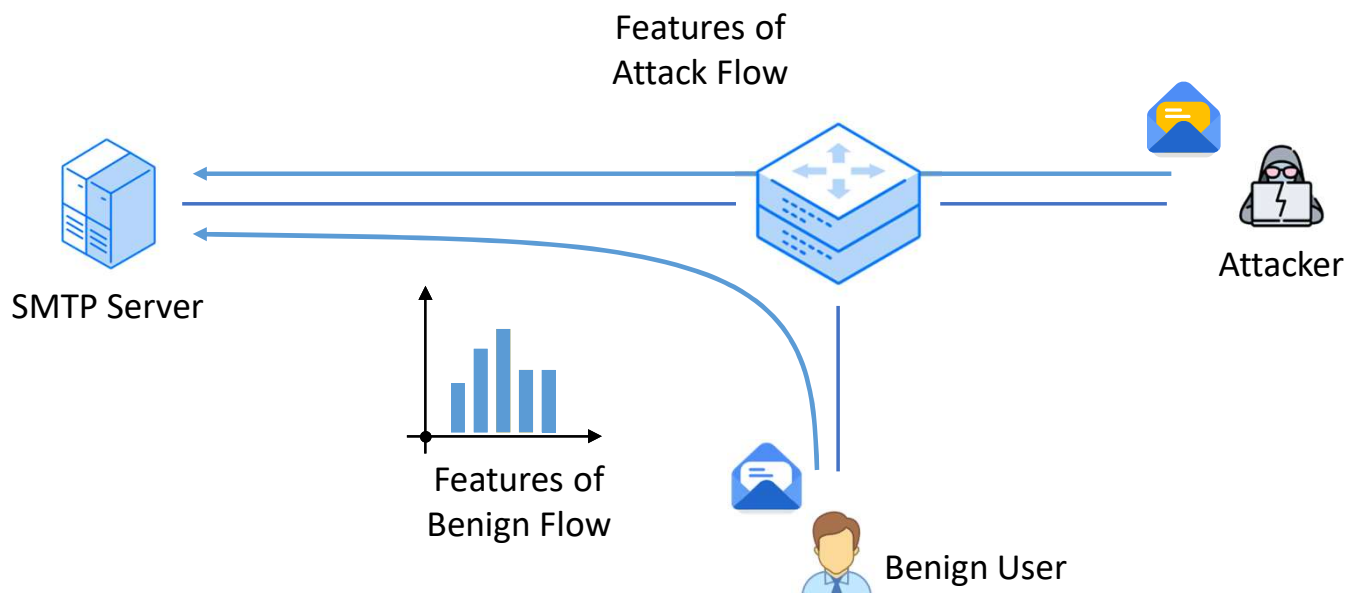


應對加密攻擊流量

■ 現有的方法無法實現通用加密流量檢測

1. 通用檢測方法：無法檢測加密攻擊，因為從傳統流量特徵角度無法區分出攻擊
2. 流量加密技術顯著混淆流量特徵，包力度和流粒度特徵都不很明顯

例如，加密的正常郵件流量和加密的垃圾郵件流量，流長度等傳統特徵無法區分他們





應對加密攻擊流量

■ 代表方案: 專用加密惡意流量識別 Anderson et. al.

分析目標: 在海量的TLS加密流量中, 識別出惡意軟件通訊的流量

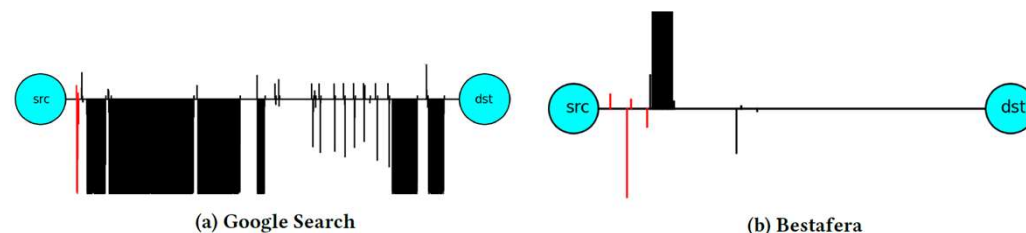
流量特徵: 采用流級別的特徵, 并且大量采用TLS包頭中的字段, 其長度超過197維

分析算法: 利用多種傳統統計機器學習方法進行檢測
評價了不同學習算法對準確度的影響

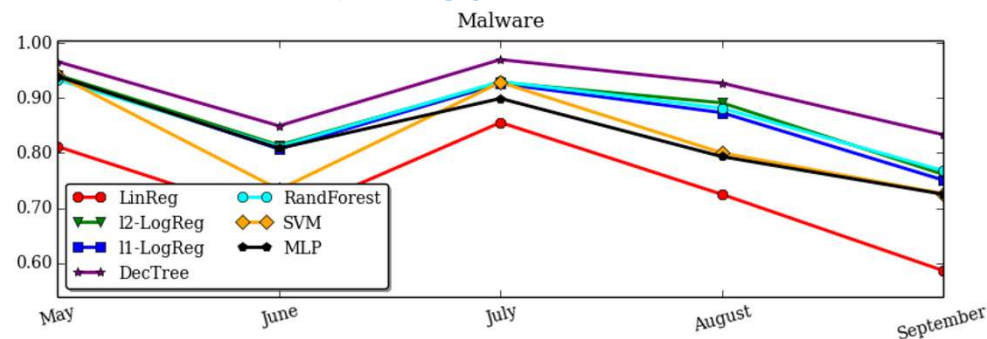
技術優勢: 最早發現利用TLS首部字段可以區分惡意軟件的流量, 例如一些罕見的TLS協議拓展只會被惡意軟件啓用

Machine Learning for Encrypted Malware Traffic Classification:
Accounting for Noisy Labels and Non-Stationarity, ACM KDD, 2017.

最早論證了TLS惡意流量的可區分性



大量采用TLS頭部特徵使得過擬合經常發生: 在長期檢測中性能顯著下降



方法將設計目標限制在加密惡意軟件流量識別上, 無法應對其他加密流量



應對加密攻擊流量

■ 代表方案: 專用加密惡意流量識別 Dodia et, al.

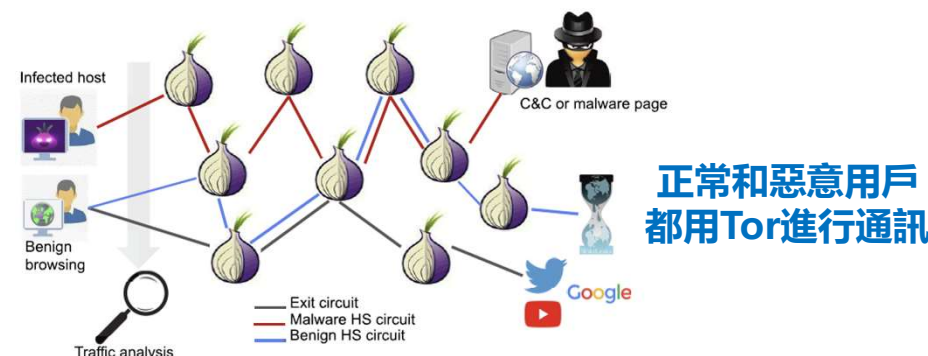
分析目標: 在Tor流量當中, 區分出惡意軟件和C2服務器進行通訊的流量

流量特徵: 采用流級別的特徵和相關的DNS流量的特徵作為檢測算法的輸入

分析算法: 利用自動機器學習算法找尋性能最好的智能算法

技術優勢: 最早發現了目前有大量惡意軟件通過Tor信道進行通訊, 因為其可以保證隱蔽性, 難以檢測此外, 利用了相關的DNS查詢作為輔助信息檢測惡意軟件相關的流量

Exposing the Rat in the Tunnel: Using Traffic Analysis for Tor-based Malware Detection, ACM CCS, 2022.



有效特徵列表

Category	Category-based Features
Duration	Average/shortest/longest duration connection No. of short duration connections (≤ 1 minute) Average duration between each Tor conn
Data	Mean/median/mode of total data exchanged Mean/median/mode of total data sent/received Mean/median/mode of total packets sent/received
Port	No. of unique DST ports used across connections Most frequent DST port used across Tor conns No. of non-standard DST ports seen Most frequent non-standard DST port
Connection	No. of connections seen (per host or PCAP) No. of failed or rejected attempts No. of connections per second No. of failed attempts per second
DNS	No. of DNS queries rcode_name: REFUSED No. of DNS queries rcode_name: SERVFAIL No. of URLs seen using "consensus" keyword No. of URLs with "tor" keyword No. of DNS queries rcode_name: NXDOMAINS Total no. of leaked onion domains No. of unique onion domains leaked No. of 'rejected' onion domain queries



應對加密攻擊流量

■ 現有的方法無法實現通用加密流量檢測

1. 通用檢測方法：無法檢測加密攻擊，因為從傳統流量特徵角度無法區分出攻擊

2. 加密流量檢測：僅可以對少數幾種加密攻擊進行檢測

[CCS'16] 提出了檢測方案僅針對惡意軟件的HTTPS流量

[KDD'17] 測量了多組惡意軟件加密流量的基線準確度

[CCS'22] 提出了基于Tor網絡通訊的惡意軟件流量檢測

[CoNEXT'12] BotFinder 方案與二進制測試結合進行惡意軟件通訊流量識別

[ACSAC'12] Disclosure 方案基于NetFlow的惡意軟件通訊流量識別

[NDSS'14] Nazca 方案提出惡意下載流量的檢測方案

[CCS'15] Webwitness 方案提出惡意站點流量檢測方法

這些方案均為有監督學習，僅針對已知的**特定類別**加密惡意流量檢測

Cisco ETA

White paper
Cisco public

The bridge to possible

Overview of Cisco Encrypted Traffic Analytics

Traditional flow monitoring provides a high-level view of network communications by reporting the addresses, ports, and byte and packet counts of a flow. In addition, intraflow metadata, or information about events that occur inside of a flow, can be collected, stored, and analyzed within a flow monitoring framework. This data is especially valuable when traffic is encrypted, because deep-packet inspection is no longer viable. This enhanced intraflow metadata is derived by using new types of data elements or telemetry that are independent of protocol details, such as the lengths and arrival times of messages within a flow. These data elements have the attractive property of applying equally well to both encrypted and unencrypted flows.

Using these data elements or enhanced intraflow telemetry to identify malware communication in encrypted traffic means Cisco® Encrypted Traffic Analytics can maintain the integrity of the encrypted flow without the need for bulk decryption (Figure 2). Table 2 lists the benefits of using Encrypted Traffic Analytics.

Figure 2. Encrypted Traffic Analytics – technical solution overview

Table 2. Benefits of using Encrypted Traffic Analytics

Benefits
Security visibility: Gain insight into threats in encrypted traffic using network analytics. Obtain contextual threat intelligence with real-time analysis correlated with user and device information.
Cryptographic assessment: Ensure enterprise compliance with cryptographic protocols and visibility into and knowledge of what is being encrypted and what is not being encrypted on your network.
Faster time to response: Quickly contain infected devices and users.
Time and cost savings: Use the network as the foundation for the security posture, capitalizing on security investments in the network.

© 2021 Cisco and/or its affiliates. All rights reserved.

© 2021 Cisco and/or its affiliates. All rights reserved.

Encrypted Traffic Analytics

- **Encrypted traffic analysis:** Gain insight into threats in encrypted traffic using network analytics. Obtain contextual threat intelligence with real-time analysis correlated with user and device information.
- **Cryptographic assessment:** Ensure enterprise compliance with cryptographic protocols and visibility into and knowledge of what is being encrypted and what is not being encrypted on your network.
- **Faster time to response:** Quickly contain infected devices and users.
- **Time and cost savings:** Use the network as the foundation for the security posture, capitalizing on security investments in the network.

Figure 2. Encrypted Traffic Analytics – technical solution overview

© 2021 Cisco and/or its affiliates. All rights reserved.



應對加密攻擊流量

■ 現有的方法無法實現通用加密流量檢測

Method	Feature	Design Goal	Generic	Realtime	Unknown
Anderson et. al.	TLS Extensions	Malware HTTPS&DNS	✗	✓	✗
Anderson et. al.	HTTPS Headers	Malware HTTPS	✗	✓	✗
BotFinder	Time Serise	Malware Comm.	✗	✗	✓
Cisco ETA	TLS Handshakes	Malware	✗	✓	✗
RADAR	Flow Statistics	Link Flooding	✗	✓	✓
Ripple	Flow Statistics	Link Flooding	✗	✗	✗
NetWarden	Flow Distribution	Covert Channel	✗	✓	✗
Dodia et. al.	Flow Features	Tor Malware Traffic	✗	✗	✗
HyperVision	Graph Features	All	✓	✓	✓

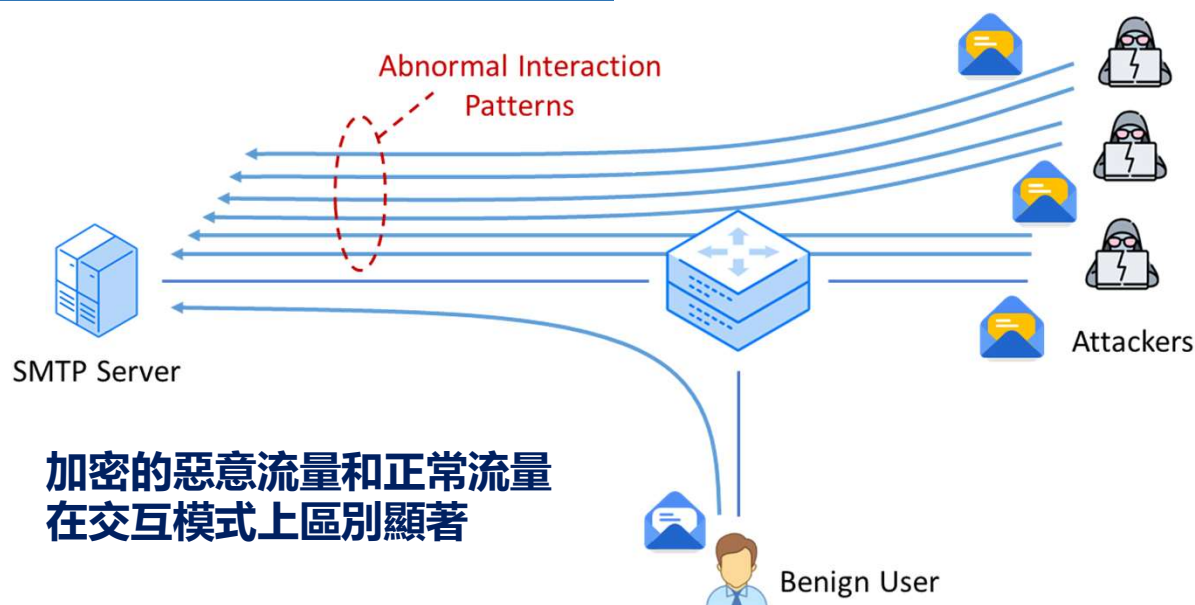
近十年加密流量識別方案性能比較



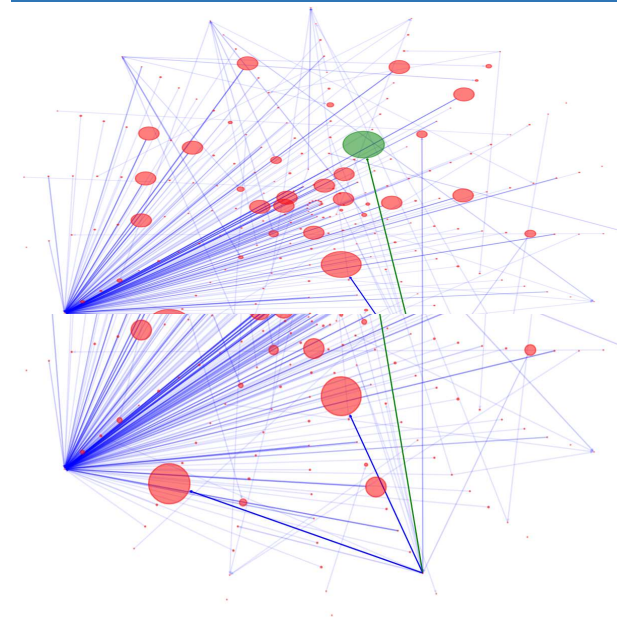
基于流量交互圖的加密惡意流量識別

- 分析目標：識別未知地加密惡意流量
 - 雖無法從單個流的特徵檢測，但可從流量**長期交互模式**中區分加密的攻擊流量
 - **構建圖結構表示節點之間的流量交互關係**

Motivation



Flow Interaction Graph





基于流量交互圖的加密惡意流量識別

■ 流量特徵：構建流量交互圖

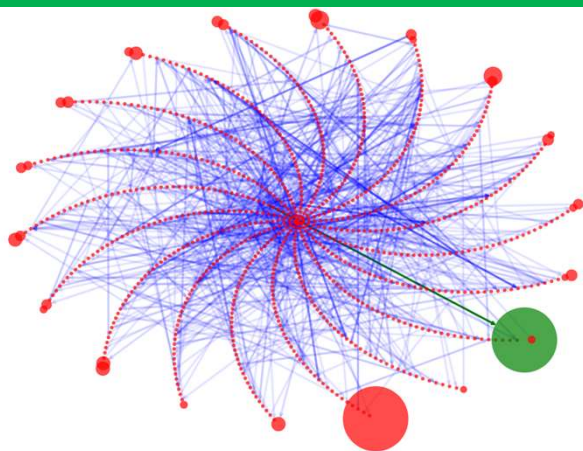
圖上的節點表示用戶，圖上的邊表示流，帶來的問題是圖的稠密寬度過高：

在AS2500當中存在超過**五萬個活躍用戶**和每小時**三百萬條流**

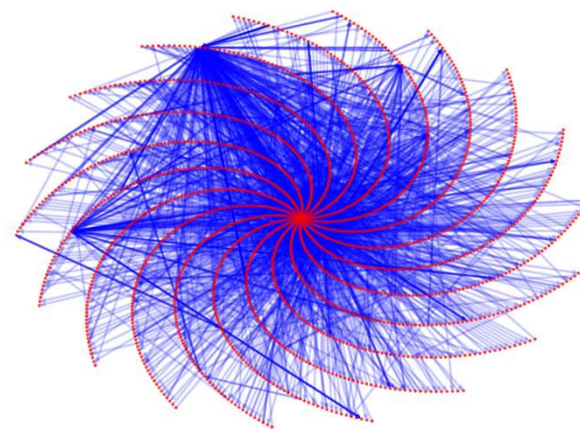
因此我們不可用一條邊表示一條流，一個節點表示一個地址

研究方案中提出一種圖壓縮算法，將相似的流合并為一個邊，相似的節點合并為一個地址

密度壓縮後



密度壓縮前



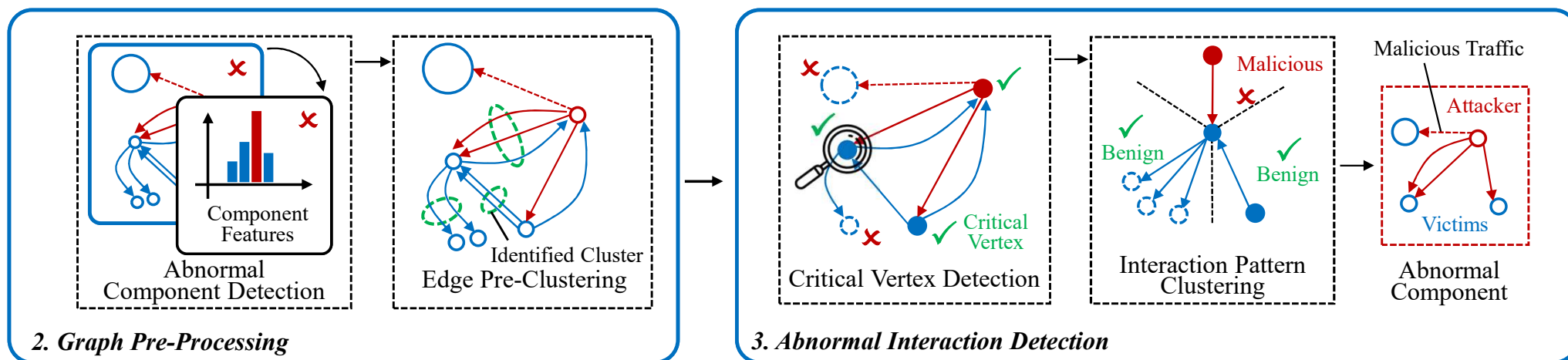


基于流量交互圖的加密惡意流量識別

■ 檢測算法：采用無監督的圖學習算法檢測出異常的圖結構，代表攻擊者和攻擊流量

預處理階段：將圖按照強連通分量拆分，并且聚集類似的邊

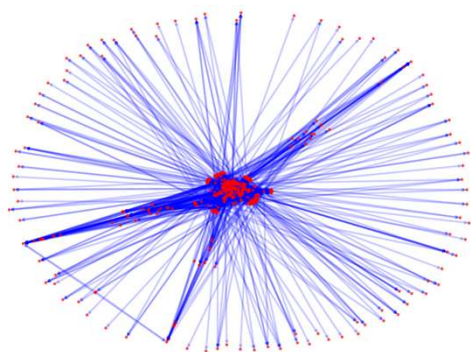
無監督圖學習階段：識別出圖上的關鍵節點，對於關鍵節點相連的全部的邊進行圖特徵聚類





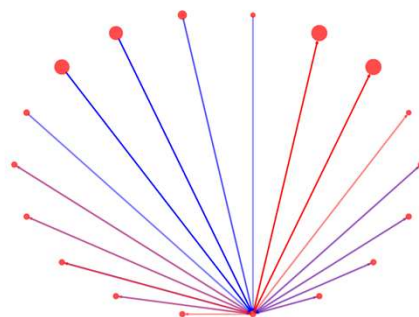
基于流量交互圖的加密惡意流量識別

■ 檢測結果：异常交互圖特徵舉例



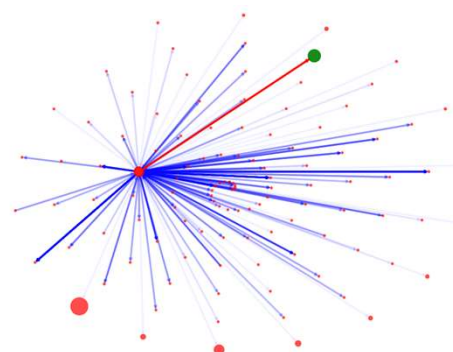
(a) Crossfire.

僵尸网络向多个目标洪范流量



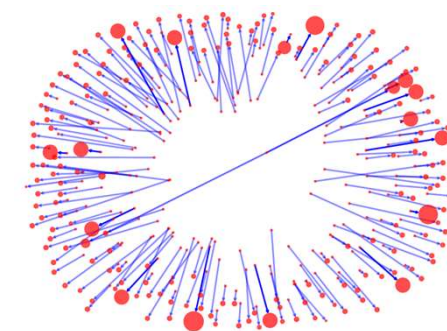
(b) SSH cracking.

攻击者猜测多个和主机的登录口令



(c) XSS detection.

攻击者向网站发送异常流量的规模区别于正常用户



(d) P2P botnet.

恶意软件洪范流量查找潜在的受害者



智能流量識別代表性方案：總結

本章中我們介紹了：

首先是，沿用傳統包內內容的智能檢測方法，這些方法本質上是對DPI檢測的直接拓展

我們介紹了**兩大類智能惡意流量檢測方法**，基于包特徵和基于流特徵的檢測方法

此外，我們特別關注兩類具備特殊能力的檢測系統：

1. 數據面上的攻擊流量檢測
2. 加密惡意流量檢測





第3節 檢測後的防禦方案

- ✓ 網絡攻擊防禦的目標
- ✓ 傳統防禦方案及其局限性
- ✓ 可編程交換機上的防禦方案



檢測後的防禦手段

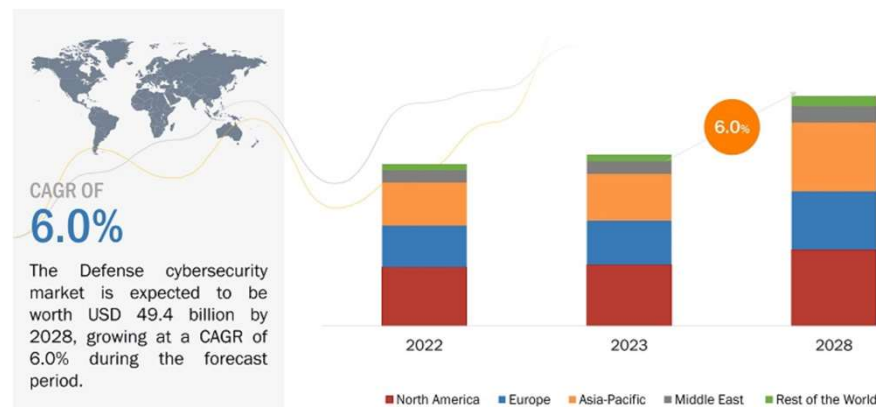
■ 技術目的

在識別出惡意流量後，得知惡意流量相關的信息，例如，攻擊者的地址和一系列流量統計信息之後，如何有效攔截攻擊者的攻擊流量

■ 技術難點

1. **防禦泛化性：**攻擊者的IP地址和惡意流量特徵變化，無法簡單通過固定規則實現防禦
2. **防禦流量規模：**對海量因特網流量進行匹配會存在較高的性能開銷，尤其是對統計特徵進行匹配，需要維護大量狀態
3. **防禦的時間效力：**部署規則快，並且在攻擊消失後儘快回復原狀
4. **防禦的空間效力：**盡可能在接近攻擊者的位置攔截攻擊流量
5. **防禦的誤傷問題：**防禦策略不應該損害正常流量

網絡防禦產品市場規模逐步上升



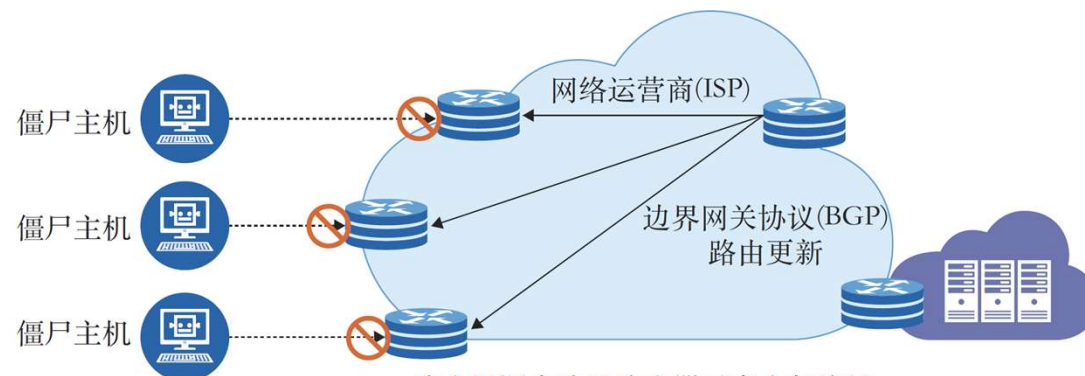


傳統防禦手段：路由黑洞

■ 技術方法

在臨近攻擊者的位置丟棄向全部被保護目標的流量，
即路由節點向攻擊者隱蔽攻擊目標

實現方法通常是由受害者所在的AS向上游節點發送
BGP Update宣告對應的網段不可達



路由黑洞在边界路由器丢弃全部流量
路由黑洞在邊界路由器丟棄全部流量

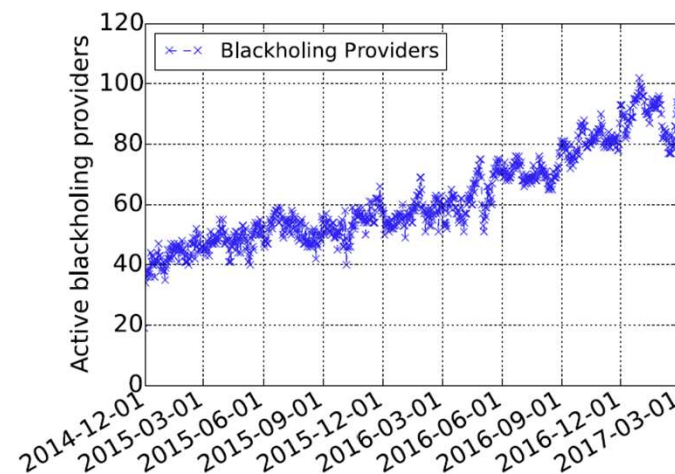
■ 技術評價

優勢：

1. 可以在進入受害者所在AS之前攔截攻擊流量
2. 可通過BGP協議直接實現不需要額外的設計和設備更新
3. 需要的信息較少，只需要受害者的地址

劣勢：

1. 靈活性差，同時攔截正常流量和惡意流量



互聯網上的路由黑洞數量統計



傳統防禦手段：IP黑名單

■ 技術方法

IP黑名單是一個攻擊者IP地址的集合，防禦者認為來自黑名單中的IP發送的流量為惡意流量

這一黑名單通常由開源社區維護，地址來自于用戶報告的威脅事件，例如進行惡意軟件分析檢測到的C2服務器IP地址

■ 技術評價

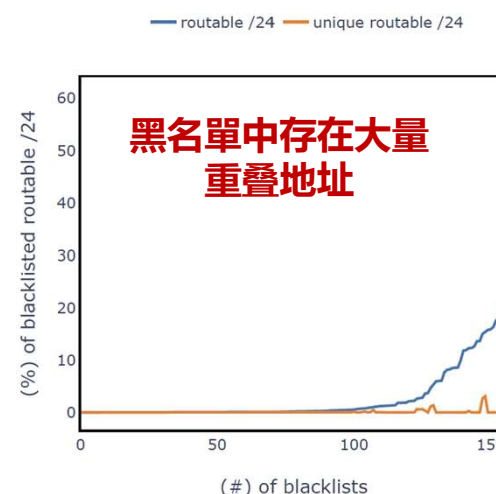
優勢：

1. 可以直接部署在防火牆
2. 在短期內有效預防攻擊

劣勢：

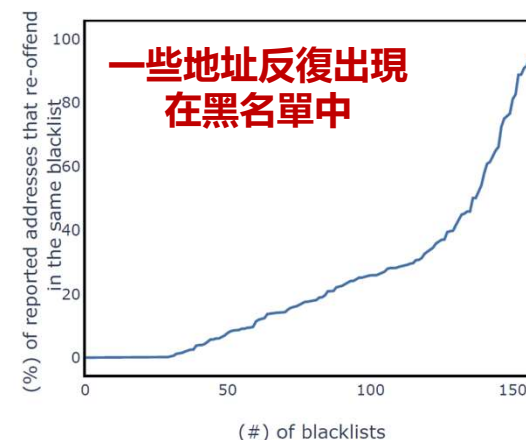
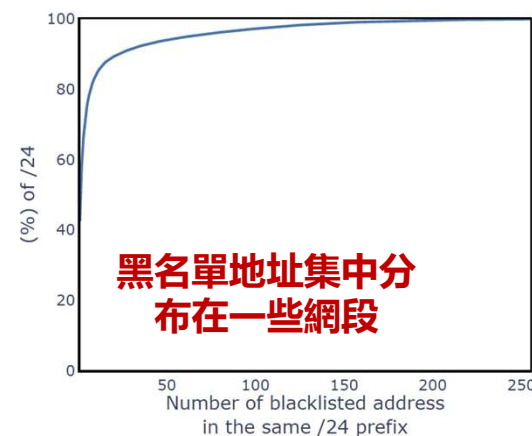
1. 靈活性差，同能時攔截正常流量和惡意流量
2. 維護IP地址列表人力資源開銷大

IP地址黑名單的特性



針對各類攻擊的黑名單存在明顯重疊

	Malware	Reputation	Spam	Attack
Attack	9.56%	77.09%	29.56%	100%
Spam	0.15%	7.08%	100%	0.37%
Reputation	1.67%	100%	71.6%	9.87%
Malware	100%	14.63%	13.2%	10.74%





傳統防禦手段：流量清洗中心

■ 技術方法

流量清洗中心 (Traffic Scrubbing Centers) 是一組擁有特徵匹配功能的網絡設備集群

對通過的流量進行**流量特徵匹配**，攔截攻擊流量，最後將正常流量返還給目的端

通常清洗中心位于**邊緣網絡**，即距離客戶端近的網絡，從而降低攻擊流量在因特網上的傳播距離

目前主流雲計算服務提供商和CDN服務提供商均提供這一服務

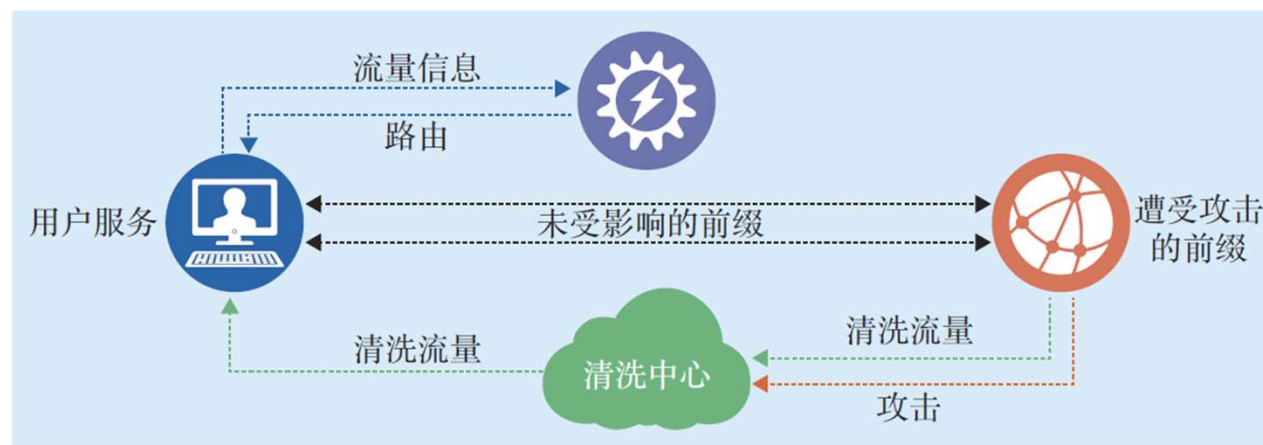
■ 技術評價

優勢：

1. 在距離邊緣節點近的位置過濾流量
2. 可以靈活按需配給

劣勢：

流量特徵匹配難以實現，因為維護流量狀態消耗大量資源，尤其是在流量規模大地址數量多的場景下



流量清洗中心高層架構



檢測後的防禦手段：可編程交換機方案

■ 技術方法

在交換機上高效部署過濾規則

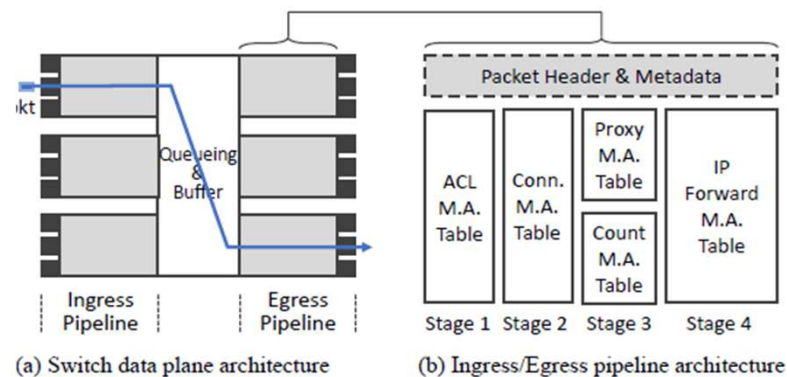
在檢測到攻擊流量後，需要對惡意流量加以限制

爲了提升傳統固定規則防火牆性能，現有方法大量采用

可編程數據面來實現更靈活的防禦

在應對大規模惡意流量例如DDoS有良好效果

可編程交換機高層次電路結構



■ 技術評價

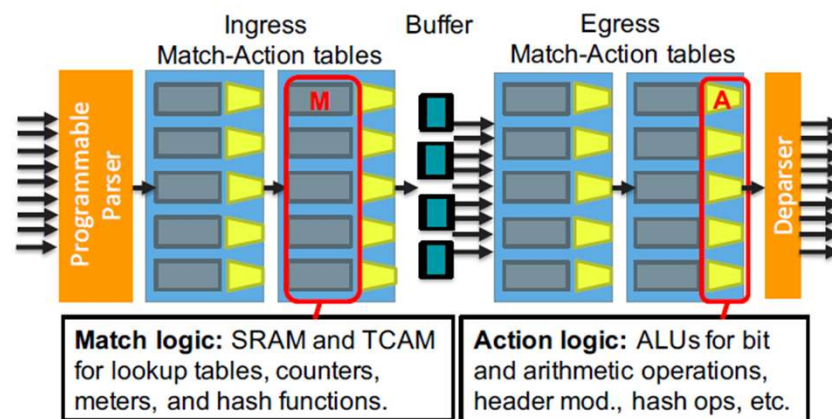
優勢：

1. 防禦方法靈活；
2. 可以應對大規模惡意流量

劣勢：

1. 可編程數據面的資源限制
2. 細粒度防禦一直難以實現

PISA的高層硬件架構





檢測後的防禦手段：可編程數據面方案

■ 代表方案: Poseidon

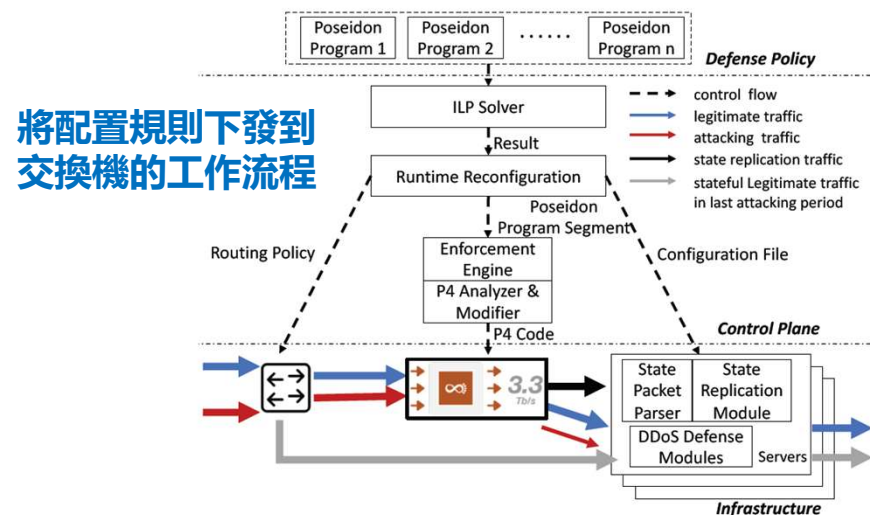
分析目標： 在海量互聯網流量當中找出滿足匹配特徵的攻擊流量

流量特徵： 在可編程交換機上，利用交換機**寄存器**提取流量特徵

分析算法： 提供一組原語，可以靈活配置匹配規則和統計規則

方案優勢： 利用交換機降低DDoS攻擊防禦的成本，即在可編程交換機上實現靈活可配置的防禦原語完成複雜的DDoS流量防禦行為

Poseidon: Mitigating Volumetric DDoS Attacks with Programmable Switches, ISOC NDSS, 2020.



Primitives	Switch Component
monitors	
$\text{count}(P, h, \text{every})$	match-action entry + count-min sketch
$\text{aggr}(P, h, \text{every})$	match-action entry + count-min sketch
actions	
drop	flow entry
pass	flow entry
rlimit	meter + flow entry
sproxy	handshake proxy + session relay
puzzle	-
log	selecting, grouping
branches	
if . . . else . . .	tag-based match action

方案實現的各種防禦原語：

統計類，主要包含各種計數器；
行為類，主要包含丟棄和限制速率



檢測後的防禦手段：可編程交換機方案

■ 代表方案: Jaqen

分析目標： 在海量互聯網流量當中找出滿足匹配特徵的攻擊流量

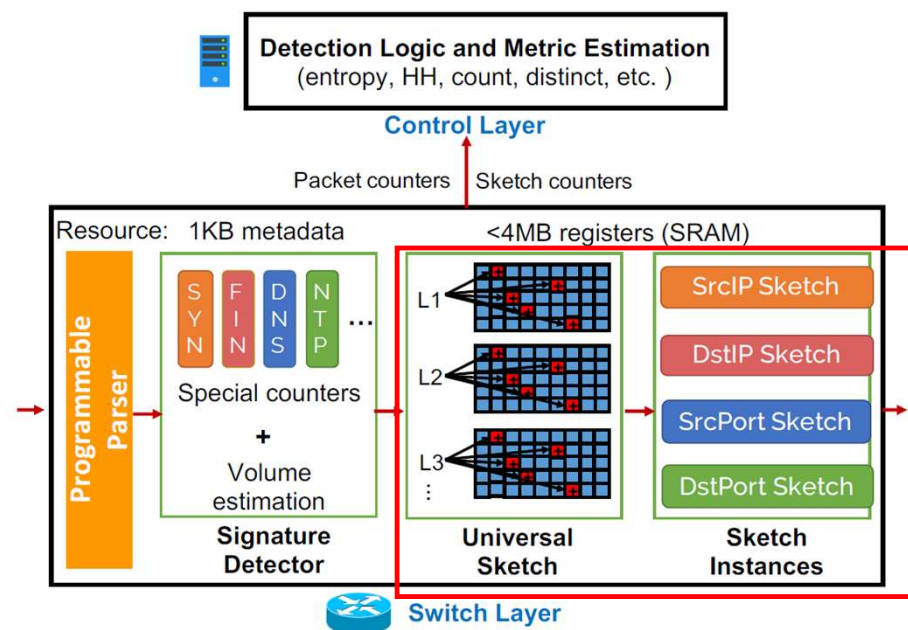
流量特徵： 在可編程交換機上，利用SRAM資源提取流量特徵；特別地，引入Sketch數據結構，對被統計地特徵進行近似統計

分析算法： 提供一組更全面原語，用戶可以靈活配置匹配規則和統計規則

方案優勢： 利用Sketch數據結構使得被統計地流的規模顯著上升，解決了Poseidon寄存器不夠用的問題

Jaqen: A High-Performance Switch-Native Approach for Detecting and Mitigating Volumetric DDoS Attacks with Programmable Switches, USENIX Security, 2021.

方案首先解析數據包而後對其進行統計
最後將統計結果報告給CPU



例如統計到達某一源地址的SYN個數

方案的核心是Sketch數據結構，在有限的交換機存儲資源下對各種粒度的統計量進行近似計算



檢測後的防禦手段：可編程交換機方案

■ 代表方案: Jaqen

Sketch 簡介:

一種近似數據結構，在有限存儲空間中計算Key針對Value的統計量、

Count-Mean Sketch: 統計總量重要指標

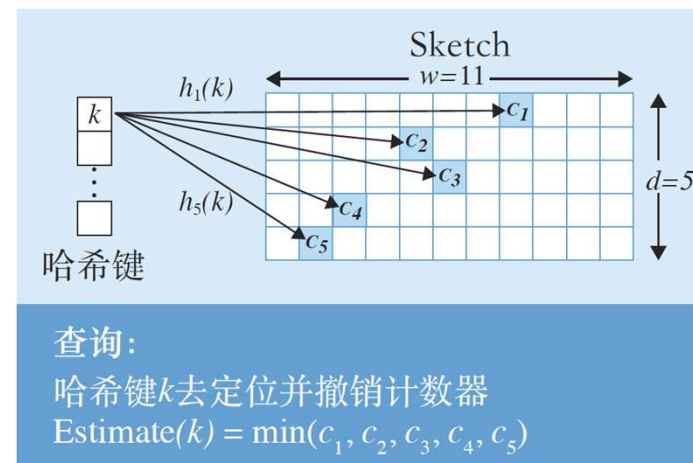
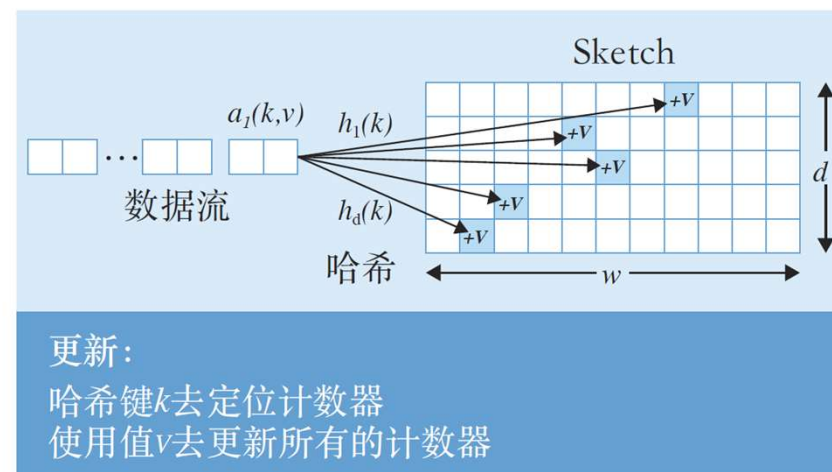
Key: 數據包的IP地址

Value: 數據包的長度

Query: 地址發送數據包的總長度

方案優勢: 存儲上界是確定的，具備良好的理論誤差界限

Jaqen: A High-Performance Switch-Native Approach for Detecting and Mitigating Volumetric DDoS Attacks with Programmable Switches, USENIX Security, 2021.





檢測後的防禦手段：可編程交換機方案

■ 代表方案: Ripple

分析目標： 在海量互聯網流量當中多個節點協作過濾出滿足條件的 Link Flooding Attack (LFA) 的流量

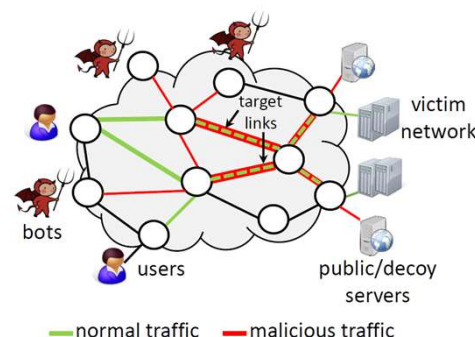
流量特徵： 在可編程交換機上，利用SRAM資源提取流量特徵，將傳統的單點部署轉變成為多點部署，節點共享統計量

分析算法： 提供一組分布式原語，可以靈活配置匹配規則和統計規則

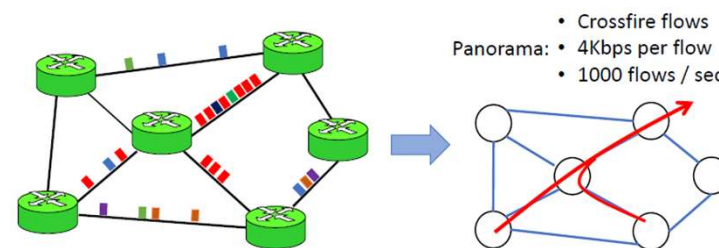
方案優勢： 將傳統單一交換設備上的規則轉換成為分布式的規則，可以對LFA進行防禦

Ripple: A Programmable, Decentralized Link-Flooding Defense Against Adaptive Adversaries, USENIX Security, 2021.

在LFA中攻擊者的目的并非某一服務器而是鏈路



提供原語查詢被阻塞的鏈路，最後緩解鏈路阻塞





檢測後的防禦手段：可編程交換機方案在總結

■ 對數據面防禦方法的評價

硬件資源的最大瓶頸

直接約束可以防禦的攻擊流的規模

硬件資源仍在提升存在困難

例如 Intel Tofino 系列可編程交換芯片已經停止更新

HARDWARE

Time to save: Intel stopped development of network switches and ended the support program for chip designers on RISC-V

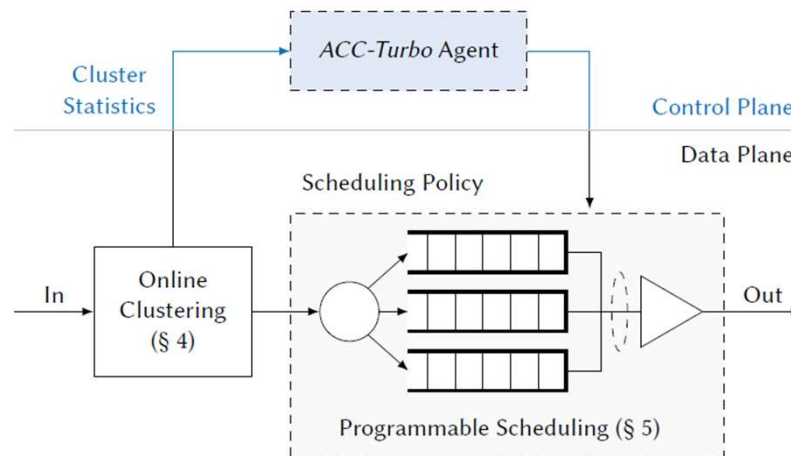
9 months ago · Dylan Harris · Add Comment

For Intel, the past fourth quarter was one of the worst, if not in history, then certainly in years — revenue plummeted 32% and the company lost \$700 million. Unsurprisingly, Intel has announced new cost-cutting measures. Discontinued investments in new products in the Network Switching Division. Intel is also ending support for the RISC-V Pathfinder program.

Aggregate-Based Congestion Control for Pulse-Wave DDoS Defense, ACM SIGCOMM, 2022

其他探究：巧妙利用攻擊流量特性進行防禦

ACC-Turbo方案，利用DDoS流量的突發特性，仿照擁塞控制算法進行防禦



該方案的核心邏輯：
只有突發的洪範流量會在交換機上產生顯著的擁塞



第4節 流量分析攻擊

- ✓ 網站指紋攻擊
- ✓ 其他流量分析攻擊
- ✓ 流量分析攻擊的防禦手段



網站指紋攻擊：威脅模型

■ 網站指紋攻擊

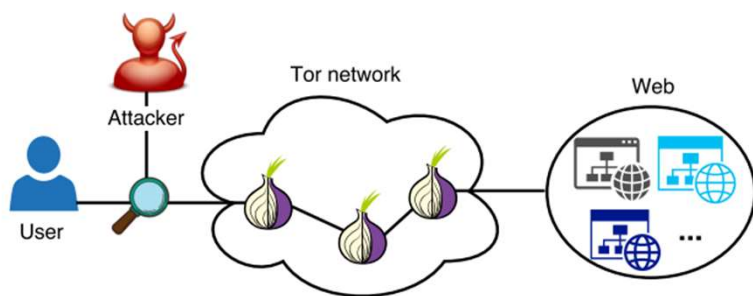
網站指紋攻擊通過分析用戶生成的Tor流量推測被訪問的網站

從而完全破壞Tor網絡隱藏被訪問的網站的功能

注意：網站指紋攻擊采集用戶加密流量的位置是用戶到Tor第一跳的位置，即距離用戶最近的節點

網站指紋攻擊 威脅模型

注意攻擊者的位置：在第一跳之前竊聽流量



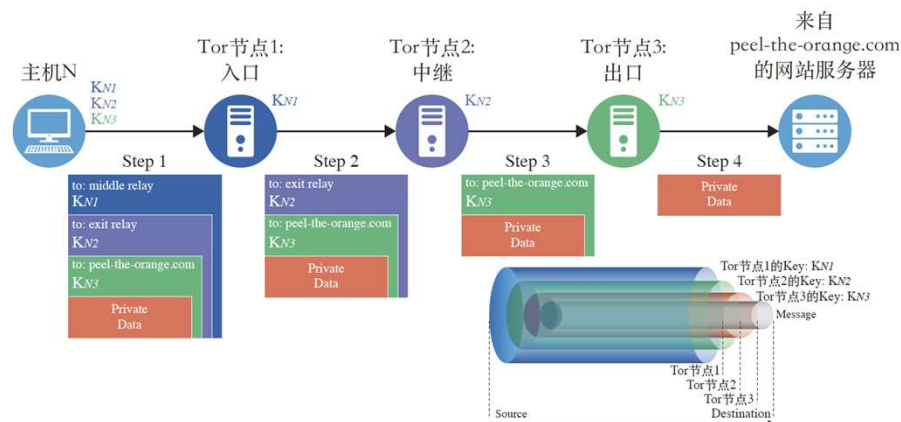
■ 網站指紋攻擊的兩大類

閉合世界假設：僅考慮用戶是否訪問一個集合中的站點

開放世界假設：考慮用戶可能通過Tor訪問任意站

在網站指紋攻擊中通常采用有監督學習算法分析流級別的特徵

洋葱網絡轉發





網站指紋攻擊

■ 代表方案：k-fingerprinting

分析目標：推測Tor流量的訪問目標網站，從而破Tor網絡的匿名性

流量特徵：篩選了20個代表性的流級別的統計特徵

分析算法：采用決策樹算法，有監督分類

方案優勢：是早期的WF的方案之一，利用決策樹的可解釋特性分析了特徵的重要度，最終指出流量分析的關鍵特徵

k-fingerprinting: a Robust Scalable Website Fingerprinting Technique, USENIX Security, 2022.

No	Feature Description
1.	Number of incoming packets.
2.	Number of outgoing packets as a fraction of the total number of packets.
3.	Number of incoming packets as a fraction of the total number of packets.
4.	Standard deviation of the outgoing packet ordering list.
5.	Number of outgoing packets.
6.	Sum of all items in the alternative concentration feature list.
7.	Average of the outgoing packet ordering list.
8.	Sum of incoming, outgoing and total number of packets.
9.	Sum of alternative number packets per second.
10.	Total number of packets.
11-18.	Packet concentration and ordering features list.
19.	The total number of incoming packets stats in first 30 packets.
20.	The total number of outgoing packets stats in first 30 packets.

研究人員發現流級別特徵可能會泄露Tor用戶訪問的站點的信息



網站指紋攻擊

■ 代表方案：ARES

分析目標：推測Tor流量的訪問目標網站，還要推測訪問網站的界面是哪一個，例如是在騰訊新聞的財經頁面還是騰訊新聞的體育界面

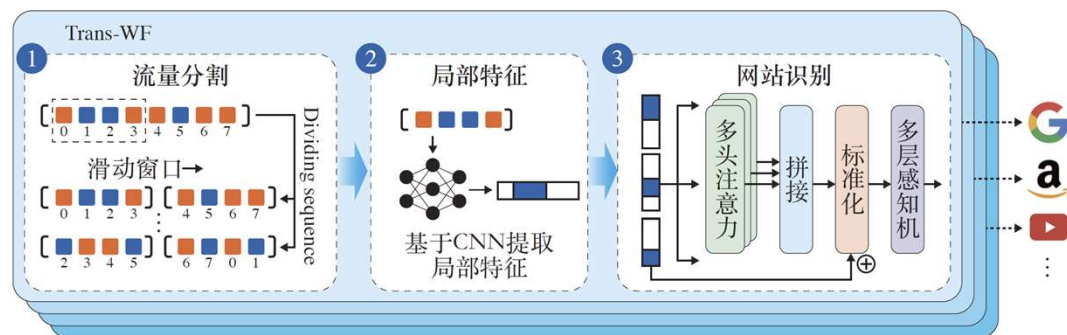
流量特徵：利用細粒度的數據包序列特徵，用數據包長度時間等特徵構成的向量拼湊為序列

分析算法：采用Transformer模型對序列進行分析，最終分類細粒度類別標籤

方案優勢：通過序列化特徵考慮數據包之間的依賴關係實現了更細粒度的流量分析

Robust Multi-tab Website Fingerprinting Attacks in the Wild, IEEE SP 2023.

首先，對一條流進行切分；而後，利用CNN對每一個片段編碼；最後利用Transformer分析片段間關係



方案細節：首先將一條Tor流量按照時間切片，而後對每一個序列用CNN進行編碼，最後訓練Transformer模型分析切片之間的依賴關係，實現細粒度的分類

在注意力機制出現後，包粒度特徵逐步被應用于WF



網站指紋攻擊

■ 代表方案：NetCLR

分析目標：在未知的網絡環境下進行WF攻擊，即實現WF對網絡的遷移性

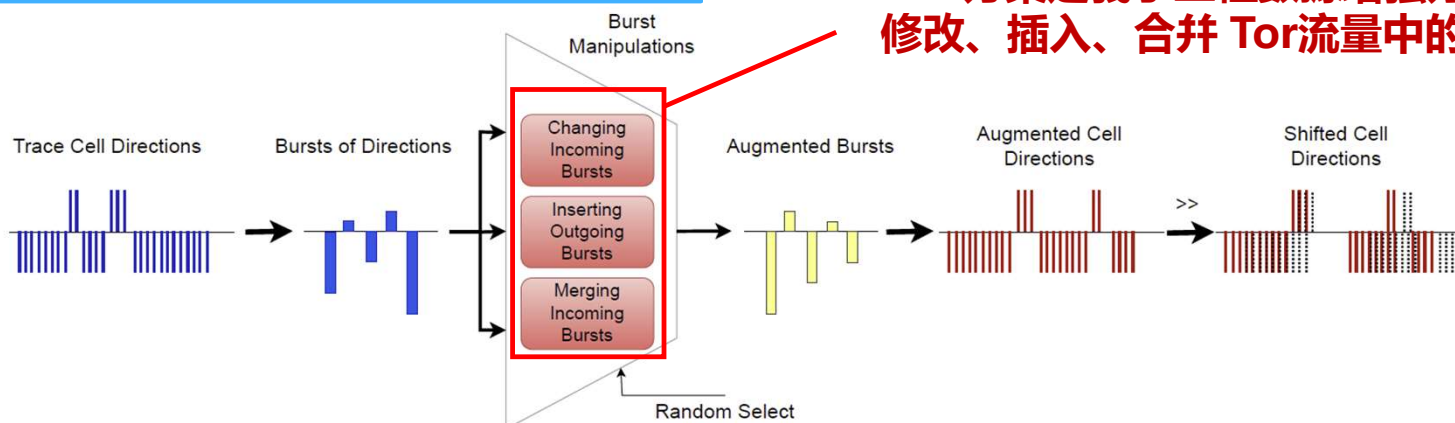
流量特徵：利流量的序列特徵，即每一個包的大小和方向，和ARES方案是類似的

分析算法：采用被預訓練的Transformer模型進行分析，這一模型被增強的流量數據進行訓練過

方案優勢：最早地解決了遷移性的問題，可以在不同的延遲和帶寬環境下完成WF攻擊

具體地，通過向流中添加擾動，模擬在不同網絡環境當中地流量

**方案定義了三種數據增強方法：
修改、插入、合併 Tor 流量中的突發部分**



Realistic Website Fingerprinting By Augmenting Network Traces, ACM CCS 2023.



網站指紋攻擊的變種：流量關聯攻擊

■ 對Tor的流量關聯攻擊

流量分析的目標：

判斷一條入端口和出端口流量是否為一個用戶生成的

Tor Enter：知道用戶的源地址但不知道目的地址

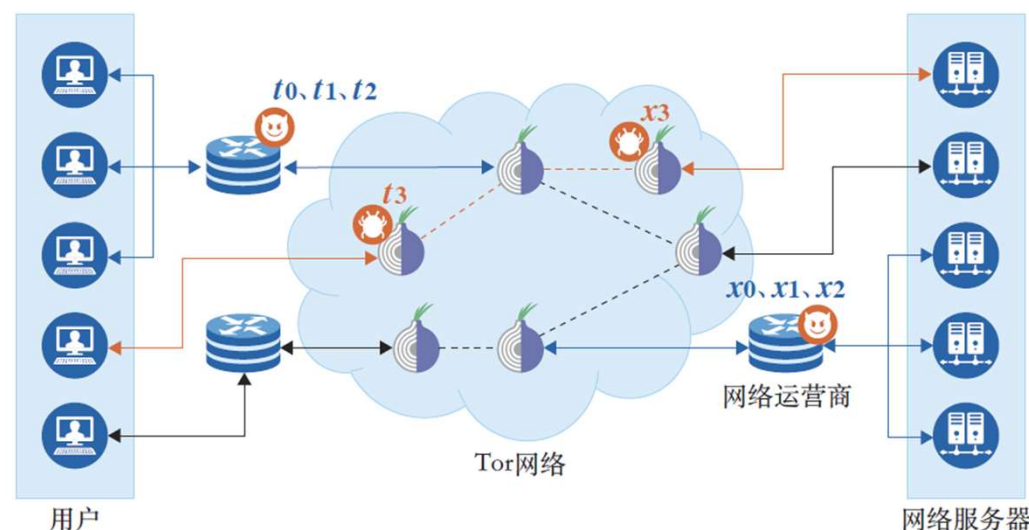
Tor Exit：知道目的地址但不知道用戶的源碼地址

但將他們的信息拼湊起來，就可以徹底破壞Tor提供的匿名性，即知道用戶和網站的對應關係

Flow Correlation Attacks on Tor Onion Service Sessions with Sliding Subset Sum, ISOC NDSS 2024.

DeepCoFFEA: Improved Flow Correlation Attacks on Tor via Metric Learning and Amplification, IEEE SP, 2022.

攻擊者需要控制兩個Tor節點進行流量竊聽



流量關聯攻擊威脅模型：
即判斷入口流量和哪一個出口流量具備相似
流量特徵



網站指紋攻擊的變種：流量關聯攻擊

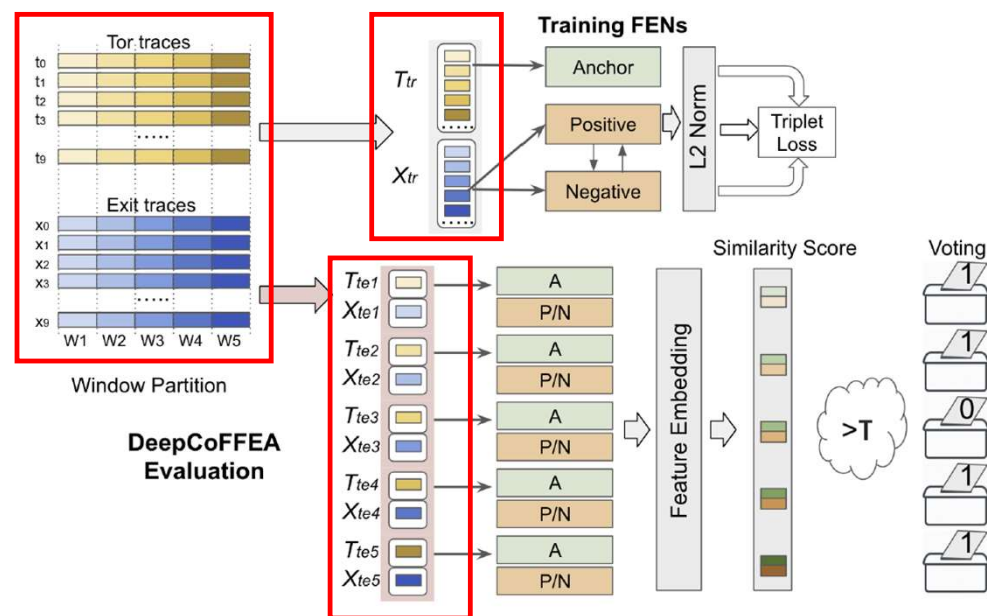
■ 代表性方案：DeepCoFFA

分析目標： 判別一個Tor出口的流量和Tor入口的流量是否為一條流

流量特徵： 流當中的每一個數據包的長度和到達時間間隔

分析算法： 卷積神經網絡，并且采用度量學習方法，即具備判定兩個輸入是否為一個的網絡

方案優勢： 最早引入了度量學習方法，在真實網絡環境下證明這一攻擊可以侵害用戶隱私



利用度量學習方法完成輸入和輸出特徵的對比

DeepCoFFEA: Improved Flow Correlation Attacks on Tor via Metric Learning and Amplification, IEEE SP, 2022.



第5節 總結與展望

- ✓ 對於流量分析系統的批判
- ✓ 流量識別的假陽性問題
- ✓ 流量分析的可解釋性問題
- ✓ 流量分析技術知識體系
- ✓ 流量分析發展的總結與展望



對於防禦方法：惡意流量識別研究的不足

■ 廣域網場景下的惡意流量識別是長期以來難以解決問題

- 入侵檢測系統之父Vern Paxon教授曾批判智能檢測方案：
- It is crucial to realize that activity found in a small laboratory network differs fundamentally from the aggregate traffic seen upstream where NIDSs are commonly deployed.*
- 呼籲在實驗室外的大型網絡評估方法



該問題
十年來未得到良好解決

逃逸、加密、隱私 三大問題



IEEE S&P'10 & Test-of-Time Award'20

USENIX Security'22 & Best Paper Award



對於攻擊方法：真實世界可行性被質疑

目標網站數的規模遠大于現有方案可以實現的數量

- 近期研究表明在真實世界環境下，分析Tor路由節點的流量在5分類時可以達到90%以上的準確度，但是當目標網站類別超過20的時候準確度快速下降到80%以下
- 呼籲在數據集當中加入真實Tor節點采集的流量

- 發現了在不同網絡環境下需要不同的WF模型，這代表著WF模型針對Tor節點的遷移性差
- 呼籲採用多樣化數據集或者生成的人工流量解決這一問題



網絡環境多樣性
攻擊目標多樣性

真實世界WF難以實現



Evaluating Website Fingerprinting Attacks on Tor in the RealWorld, USENIX Security 2022.

Realistic Website Fingerprinting By Augmenting Network Traces, ACM CCS, 2023.



第5節 總結與展望

- ✓ 對於流量分析系統的批判
- ✓ **流量識別的假陽性問題**
- ✓ 流量分析的可解釋性問題
- ✓ 流量分析技術知識體系
- ✓ 流量分析發展的總結與展望



流量識別系統的假陽性問題

■ 在真實世界部署當中的人工處理壓力：對假陽性問題的批判從來沒有停止過

- 近期研究發現在Security Operating Centers (SOCs) 中存在大量的假陽性警報，即正常行為觸發檢測系統的警報
- 這種假陽性警報至多占據99%的比率



99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms
USENIX Security, 2022

- 近期研究進一步發現假陽性對真實世界部署識別系統至關重要，直接影響流量識別系統在真實世界的評價、測試、和運行



Alert Alchemy: SOC Workflows and Decisions in the Management of NIDS Rules, ACM CCS, 2023.

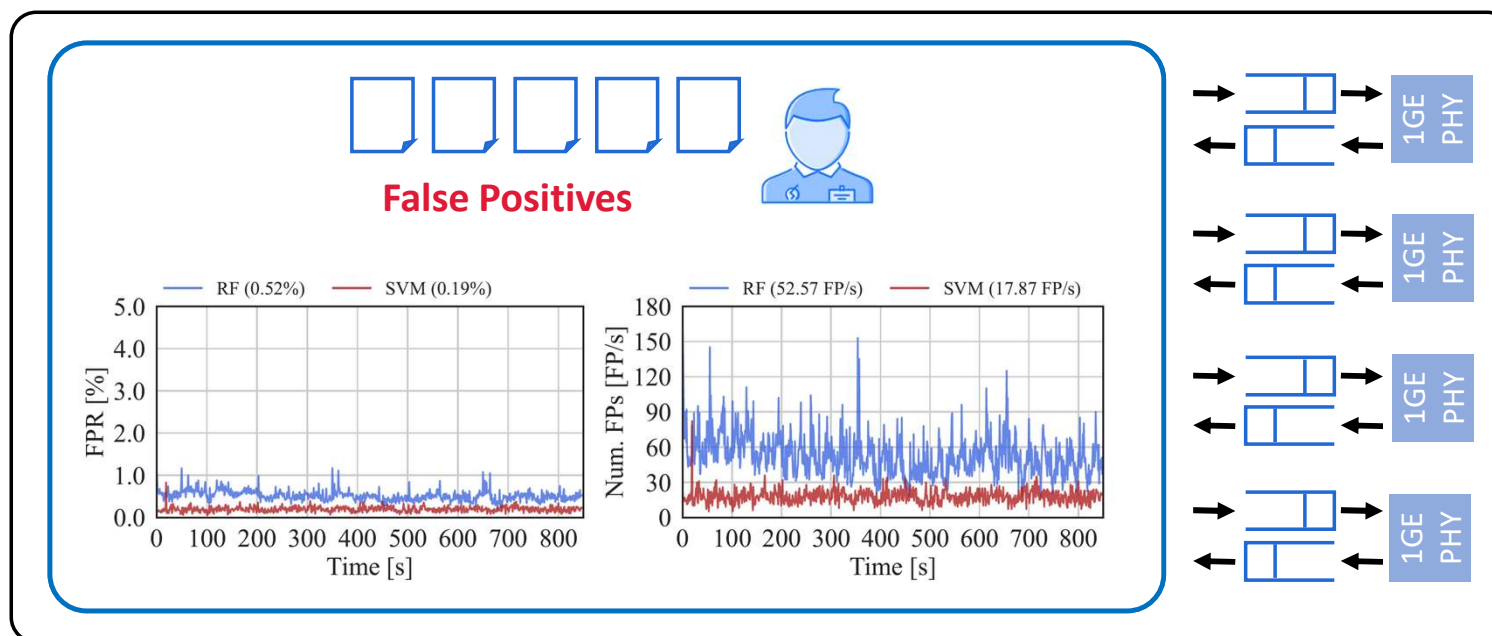


流量識別系統的假陽性問題

■ 假陽性問題十分嚴重：

大量產生假陽性的根本原因是流量規模本身就會特別大

導致人類專家必須手動從全體警報當中分理出假陽性警報



$$1\text{M Flows} * 0.01\% \text{ FPR} = 10\text{K False Alarms}$$



流量識別系統的假陽性問題

■ 假陽性問題十分嚴重：

傳統的降低假陽性率的兩種方法：均是利用已知假陽性警報和其他任務相關信息

1. 重訓練方法：

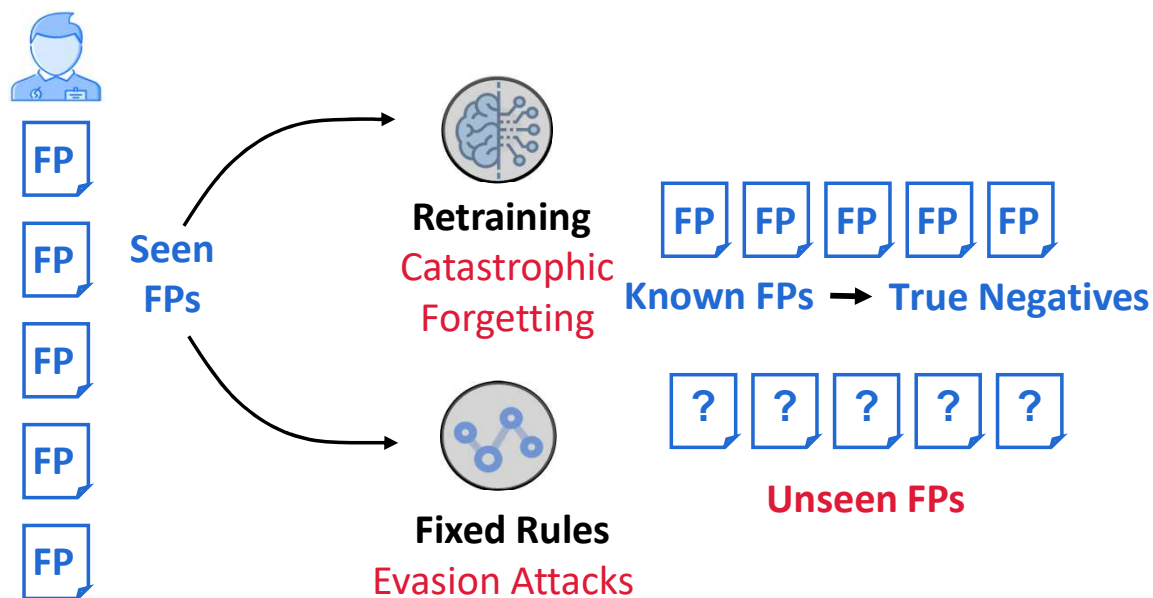
將被人工識別出來的假陽性警報加入數據集，對模型進行重訓練，即可降低相似的假陽性警報

方法的不足：需要額外的計算開銷，并且對黑盒模型不可用，例如成熟的商業流量識別軟件

2. 固定規則方法：

對全體陽性樣本進行規則匹配，過濾出部分的假陽性警報，例如采用IP地址白名單和AS信用度量

方法的不足：需要額外的領域知識，并且泛化性差，只能適用於已知的網絡環境

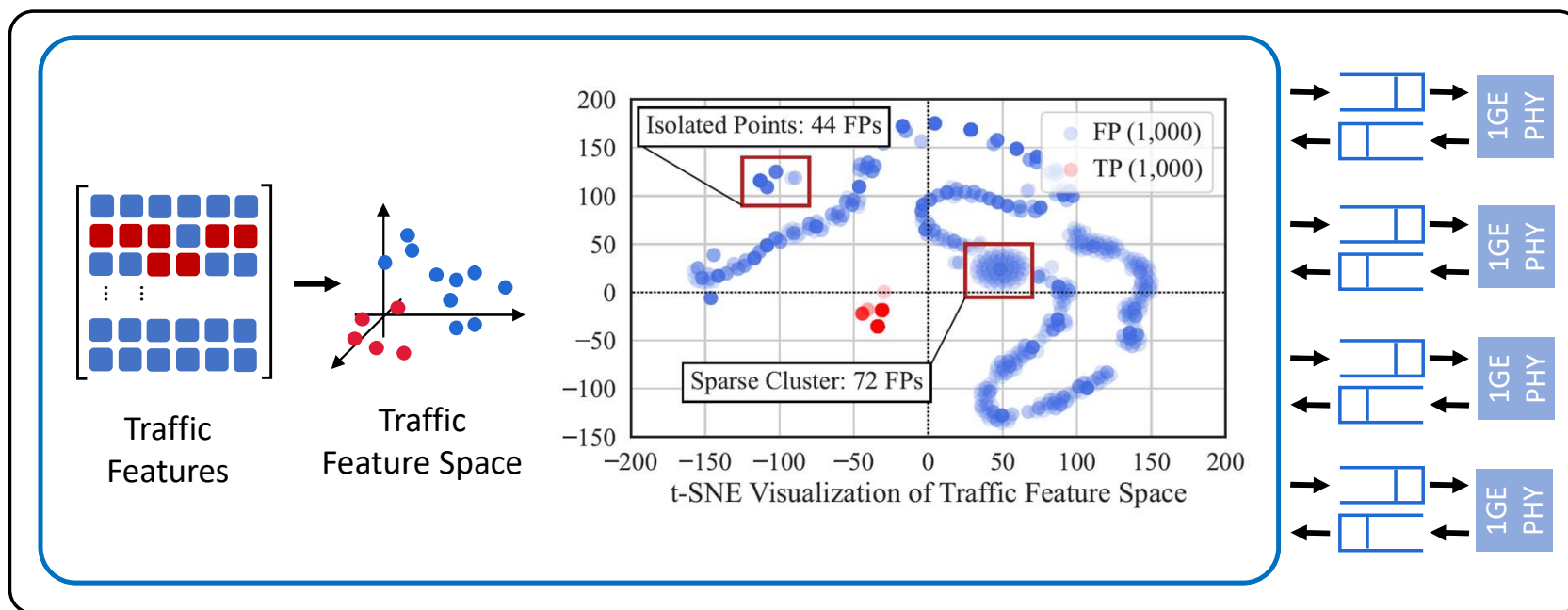




流量識別系統的假陽性問題

■ 解決流量分析的假陽性問題：pVoxel方案 (ACM CCS 2023)

利用流量特徵在特徵空間當中的分布特性



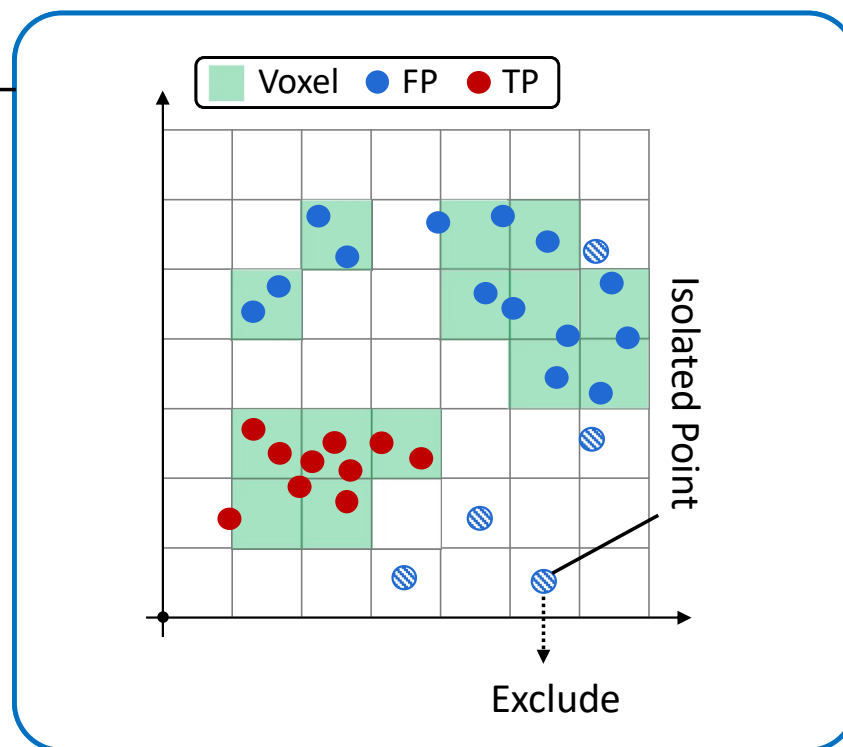
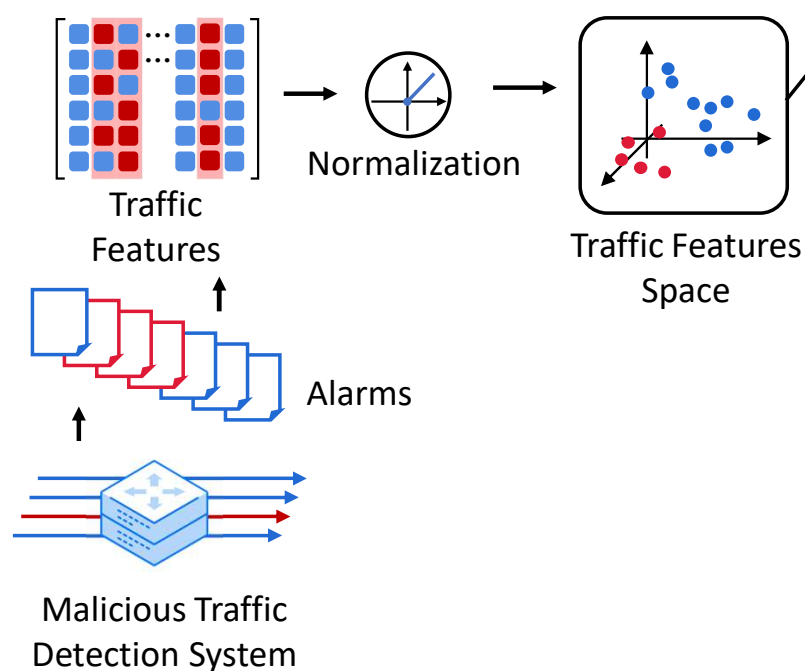
正常流量的特徵在特徵空間稀疏分布，異常流量的特徵在特徵空間當中稠密分布



流量識別系統的假陽性問題

■ 解決流量分析的假陽性問題： pVoxel方案 (ACM CCS 2023)

利用流量特徵在特徵空間當中的分布特性



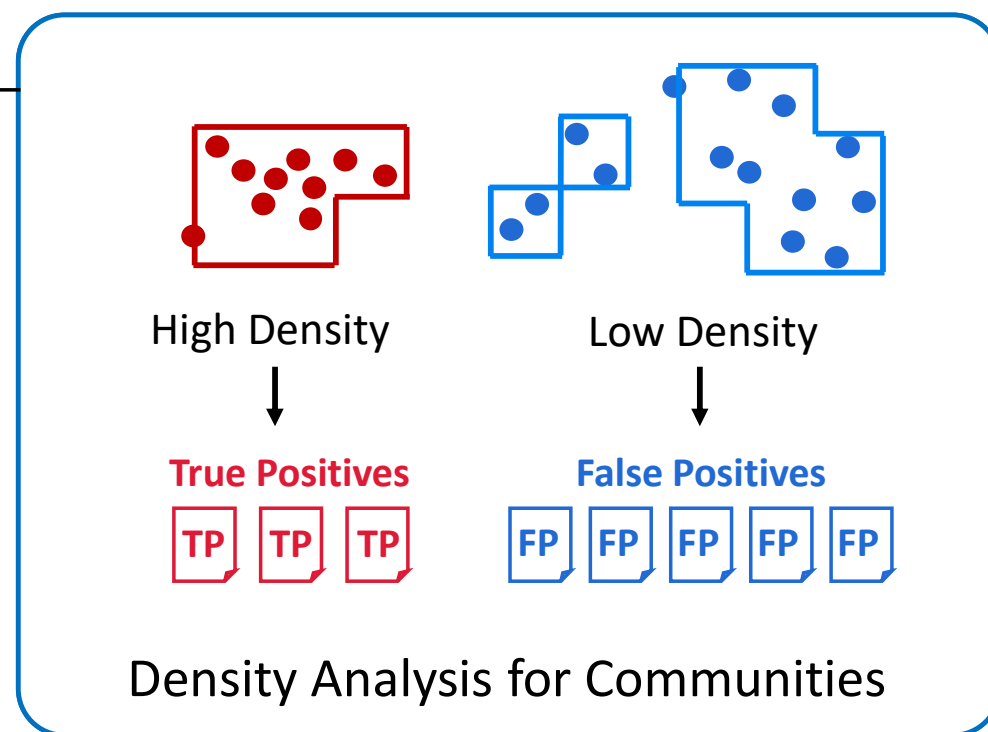
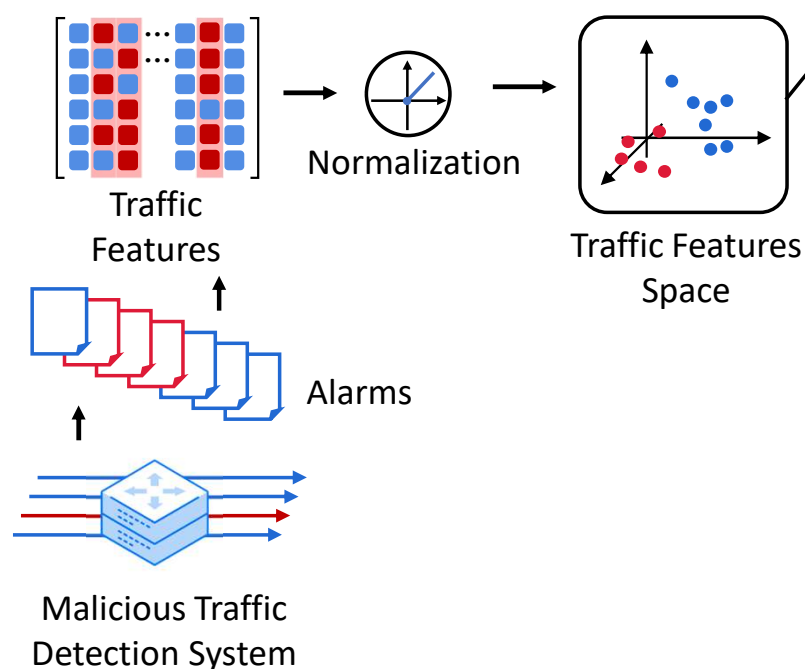
收集全體陽性樣本，分析在特徵空間的分布特性：
將稠密分布的分類為真陽性，將稀疏分布的分類為假陽性



流量識別系統的假陽性問題

■ 解決流量分析的假陽性問題： pVoxel方案 (ACM CCS 2023)

利用流量特徵在特徵空間當中的分布特性



該方案可以為目前最先進的11種流量識別系統降低超過95%的假陽性警報



第5節 總結與展望

- ✓ 對於流量分析系統的批判
- ✓ 流量識別的假陽性問題
- ✓ **流量分析的可解釋性問題**
- ✓ 流量分析技術知識體系
- ✓ 流量分析發展的總結與展望

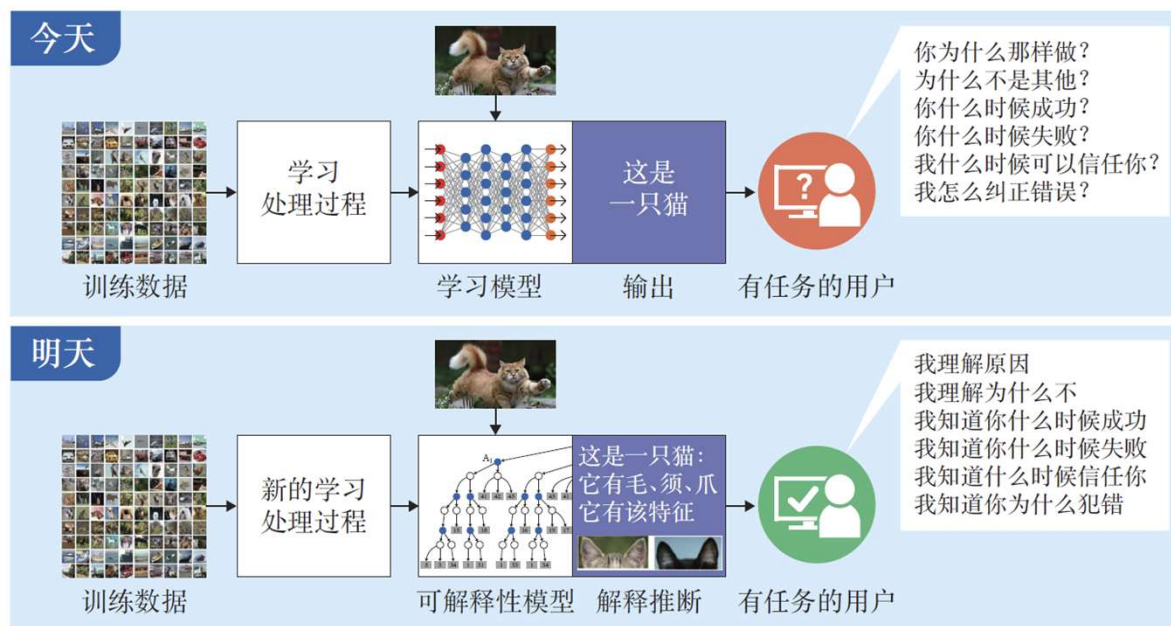


機器學習的可解釋性問題

■ 可解釋機器學習 Explainable AI

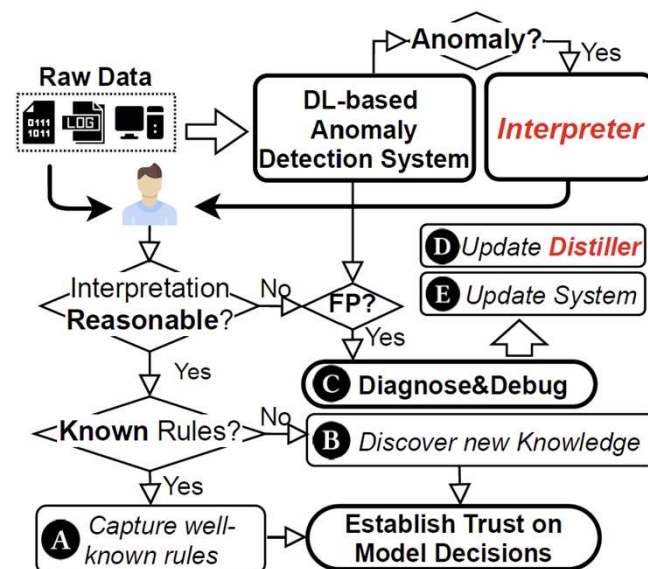
目的在于解釋為什麼機器學習做出這類決策

現有方法普遍標記重要特徵，解釋基于哪一特徵做出了決策



可解釋性對安全任務極為重要

必須知道模型為何做出決策，才能在真實世界部署，及解決異常為何是異常的難題

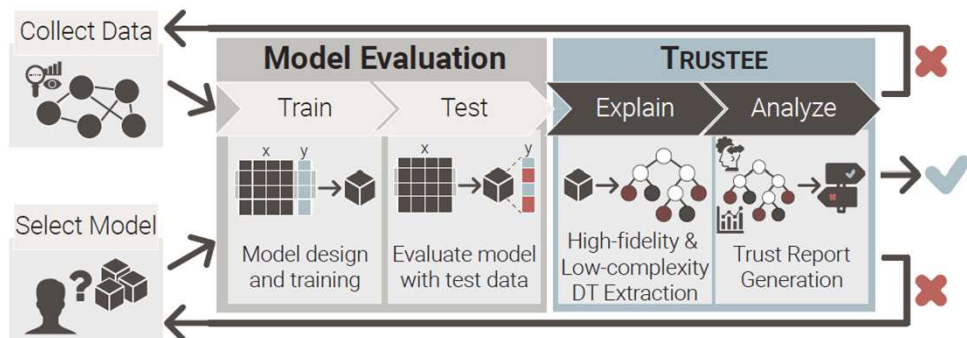




機器學習的可解釋性問題

■ 代表性模型解釋方法：Truesteeml

將DL/ML模型轉換成爲決策樹，通過樹狀結構發現用于模型決策的關鍵特徵和決策路徑



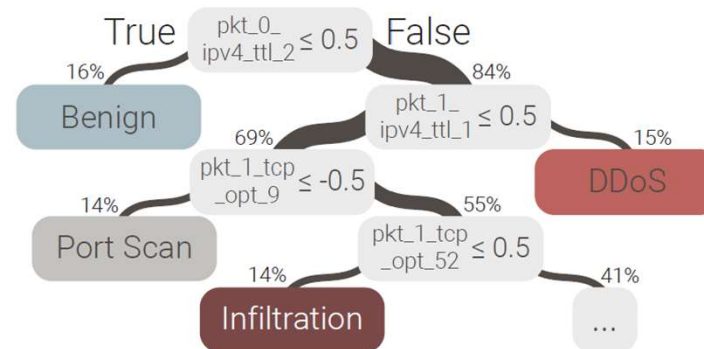
通過解釋模型，可以得到生成運維人員對模型的信任，進一步地約束假陽性和進行模型調優

AI/ML for Network Security: The Emperor has no Clothes, ACM CCS, 2022.

	0																9	10																19
Pcap	0	161	178	195	212	0	2	0	4	0	0	0	0	0	0	0	0	0	255	255														
Meta	20	0	0	0	1	85	65	10	69	0	5	80	24	0	0	0	64	0	0	64														
Eth	40	Destination MAC Address								Source MAC Address																								
		1	0	94	0	0	252	184	172	111	54	28	162	8	0	69	0	0	50	65	228													
IPv4	60	0	0	1	17	34	185	131	202	240	87	224	0	0	252	201	86	20	235	0	...													

	0																9	10																19
Pcap	0	161	178	195	212	0	2	0	4	0	0	0	0	0	0	0	0	0	255	255														
Meta	20	0	0	0	101	85	45	101	91	0	0	111	11	0	0	0	56	0	0	56														
Eth	40	Total Length								Frag.Off.								Protocol																
IPv4	60	69	0	0	56	99	213	6	0	0	17	5	254	10	8	0	10	69	171	255	36													
UDP		146	214	13	150	0	36	120	43	0	1	0	8	33	18	164	66	52	167	9	...													

識別出數據包中對分類貢獻度大的字段



將決策過程轉換成爲一個決策樹



第5節 總結與展望

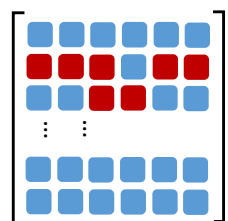
- ✓ 對於流量分析系統的批判
- ✓ 流量識別的假陽性問題
- ✓ 流量分析的可解釋性問題
- ✓ **流量分析技術知識體系**
- ✓ 流量分析發展的總結與展望



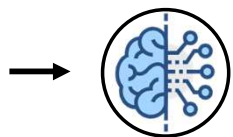
流量分析的應用盤點

總結流量分析系統的目的

流量分析系統根據目推測的目標被分成兩大類，但其實質性技術均為流量分析：
根據流量特徵推測流量信息



流量特徵



分析算法



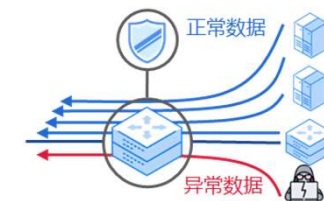
目標信息

好的目的

入侵檢測和防禦
推測流量異常與否

目標未知

攻擊流量檢測系統



攻擊流量防禦系統



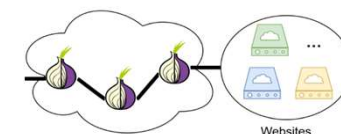
目標已知

壞的目的

流量分析攻擊

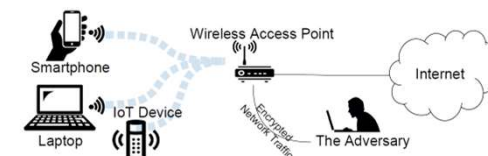
推測流量中的隱私

針對Tor



網站指紋生成

其他應用



APP指紋生成與其他加密
流量指紋生成

如何系統化地分析流量分析系統：
抓住流量分析系統的三要素



流量分析的系統的架構的三要素和分類法

■ 流量分析系統的三要素：流量特徵、分析算法、分析的目的

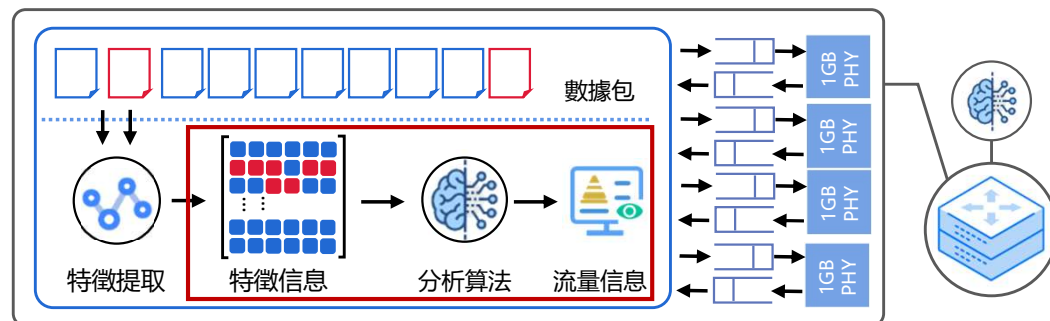
- › **流量特徵：**系統采用了何種方法表示流量
 - › 負載特徵：直接將數據包當中地內容作為特徵
 - › 統計特徵：例如對於數據包頭部內容設計統計量

其中，**流量特徵**是影響系統性的關鍵

- › **檢測算法：**固定規則和機器學習算法
 - › 固定規則：由人類專家設計
 - › 機器學習：算法根據已知數據訓練
- › **分析的目的：**
 - › 竊取隱私：流量分析攻擊
 - › 保護用戶：流量的識別和防禦

流量分析系統的分類法			
分析目的	檢測算法	特徵	實際應用
保護用戶	固定規則	統計特徵	攻擊流量防禦系統 (3.1-3.3)
		負載特徵	傳統固定規則入侵檢測 (1.1)
	機器學習	包頭特徵	智能入侵檢測系統 (2.1 - 2.5)
		負載特徵	網站防火牆應用 (1.3)
隱私竊取	固定規則	包頭特徵	網絡側信道攻擊 (第八章)
		負載特徵	流量竊聽 (第八章)
	機器學習	包頭特徵	流量分析攻擊 (4.1 - 4.3)
		負載特徵	-----

本課程通過三要素模型：
將全部的流量分析系統放在同一框架下研究





本章內容關聯性和教學目標

攻擊流量的檢測和防禦

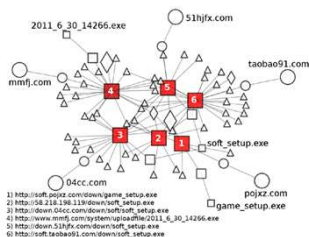
從海量的數據包當中抽取流量特徵，推斷攻擊流量是否為正常或者異常，從而實現檢測和攔截攻擊流量，保護大量互聯網用戶的安全性

基于流量特徵的隱私竊取

根據加密流量的特徵，預測流量通訊內容相關的隱私信息

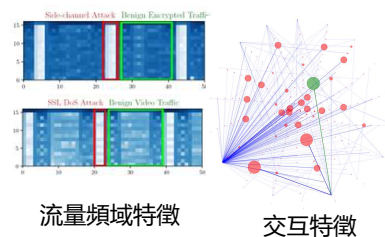
負載特徵流量識別

研究內容:
傳統NIDS
網站防火牆



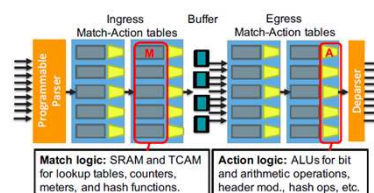
統計特徵流量識別

研究內容:
流粒度、包粒度特徵
加密流量識別



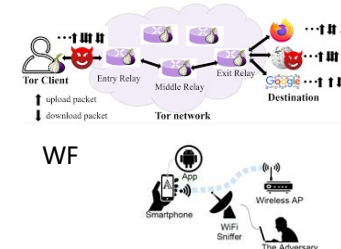
攻擊流量防禦系統

研究內容:
傳統匹配過濾機制
可編程數據面防禦機制



流量分析攻擊

研究內容:
網站指紋生成
其他流量分析攻擊



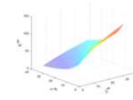
未知攻擊
高效信息使用



未知攻擊
未知流量模式



流量規模
海量流量匹配



竊取信息
高效信息使用

我們以流量分析系統三要素為切入點，系統化分析各種流量識別系統



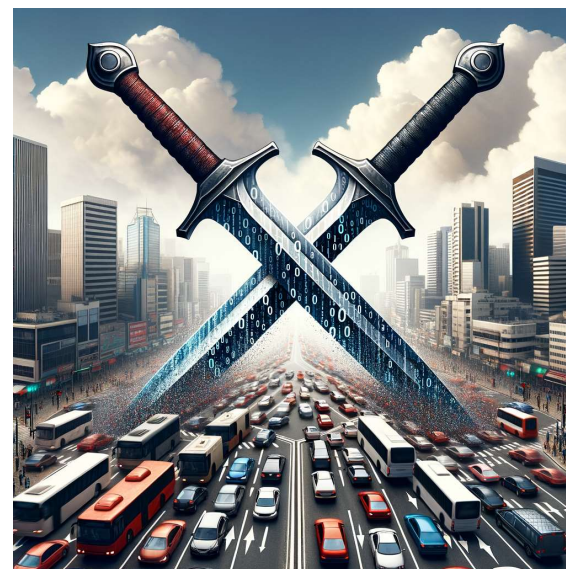
第5節 總結與展望

- ✓ 對於流量分析系統的批判
- ✓ 流量識別的假陽性問題
- ✓ 流量分析的可解釋性問題
- ✓ 流量分析技術知識體系
- ✓ **流量分析發展的總結與展望**



技術價值觀：網絡技術的雙刃劍屬性

- **流量分析技術可以用于攻擊，也可用于防禦**
 - › **流量檢測系統**：根據流量特徵推測流量是否為惡意
 - › **流量分析攻擊**：根據流量特徵推斷用戶隱私信息
 - › 二者在技術上的相似性，必然導致了流量分析在真實世界的困難性：
 - › 例如，如何防止流量識別系統抓取流量進行流量分析攻擊
 - › 目前抓包分析被大量網絡服務提供商禁止



要解決流量分析技術的隱私難題，利用流量分析技術保護網絡安全需要行政法規保障，同時也需要研究人員具有正確的技術價值觀



將流量分析技術應用于真實世界

■ 真實世界應用流量分析技術，釋放人工智能的強大能量保護網絡安全，需要解決一系列難題：

› 隱私保護難題：

- › 流量數據攜帶用戶隱私，部署技術受到嚴格顯著

› 真實世界泛化性：

- › 真實世界的網絡環境複雜多變，為分析魯棒性提出挑戰

› 人類用戶可用性：

- › 解決假陽性人工分析開銷問題，和可解釋性問題

› 硬件設備部署難題：

- › 真實流量規模大，如何部署到高性能網絡設備上



**目前，真實世界大規模部署流量分析，保護網絡基礎設施安全
仍然面臨巨大挑戰**